

Fundamentos da Segurança Cibernética - Introdução ao CIS Controls

Fundação Escola Nacional de Administração Pública

Diretoria de Desenvolvimento Profissional

Conteudista/s

Antônio João Gonçalves de Azambuja (conteudista, 2024).



Enap, 2023

Fundação Escola Nacional de Administração Pública

Diretoria de Desenvolvimento Profissional

SAIS - Área 2-A - 70610-900 — Brasília, DF

Sumário

Módulo 1: Fundamentos	6
Unidade 1: O que é a Era Digital?	6
1.1 Privacidade	7
1.2 Segurança da Informação - SI	10
1.3 Segurança Cibernética	15
1.4 Glossário de Segurança da Informação	17
Referências	18
Módulo 2: Fundamentação e estruturação dos controles	19
Unidade 1: Abordagem de controles e implementação de cibersegurança ...	19
1.1 Leis	19
1.2 Decretos	21
1.3 Portarias	23
1.4 Normas	24
1.5 Resoluções	26
1.6 Estratégia Nacional de Segurança Cibernética	26
1.7 Política Nacional de Segurança da Informação	28
1.8 Estratégia de Governo Digital	30
Referências	31
Módulo 3: Gestão de Segurança da Informação	32
Unidade 1: Política de Segurança da Informação	32
1.1 Escopo	32
1.2 Conceitos e Definições	34
1.3 Princípios	36
1.4 Diretrizes	37
1.5 Competências	39
1.6 Penalidades	39
1.7 Políticas de atualização	39

Unidade 2: Gestão de Riscos	40
2.1 Principais definições.....	40
2.2 Modelo de gestão de riscos institucional	42
2.3 Documentação: Plano de gestão de riscos, Relatório de identificação, análise e avaliação dos riscos e Relatório de tratamento de risco	45
2.3.1 Plano de Gestão de Riscos	46
2.3.2 Relatório de Identificação, análise e avaliação de Riscos.....	47
2.3.3 Relatório de Tratamento de Riscos.....	48
2.4 <i>Compliance</i> : Importância no contexto da Segurança da Informação e Segurança Cibernética.....	50
Unidade 3: Gestão de Incidentes	51
3.1 Principais definições.....	51
3.2 Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos	54
3.3 Centro de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos de Governo.....	58
3.4 Centro Integrado de Segurança Cibernética do Governo Digital	59
Unidade 4: Principais conceitos de sensibilização, conscientização e capacitação	60
4.1 Ações de sensibilização, conscientização e capacitação	60
4.2 Instrução Normativa nº 1, de 27 de maio de 2020.....	63
4.3 Controle 14 – Conscientização sobre segurança treinamento de competências...65	
Referências	66
Módulo 4: Frameworks de Segurança	67
Unidade 1: Frameworks	67
1.1 Importância	67
1.2 Como funcionam	69
1.3 Como utilizar	71
1.4 <i>Frameworks</i> disponíveis	72
1.5 <i>Framework</i> de Privacidade e Segurança da Informação (SGD/MGI).....	73
1.5.1 Estruturação básica de gestão em privacidade e segurança da informação (Controle 0) - Anexo III.....	75
1.5.2 Segurança Cibernética (1 a 18)	77
1.5.3 Controles de Privacidade (19 a 31).....	78
Referências	79

Módulo 5: Visão Geral do CIS Controls.....	80
Unidade 1: Visão geral.....	80
1.1 Sobre o <i>CIS Controls</i>	80
1.2 Como começar.....	80
1.3 Estrutura.....	81
1.4 Guias do CSI.....	82
1.5 Perfis.....	82
1.6 Visão geral dos <i>CIS Controls</i>	83
Referências	96
Glossário	97

1 Fundamentos

Bem-vindo(a)

O objetivo deste módulo é apresentar os principais conceitos relacionados à privacidade, segurança da informação e segurança cibernética, possibilitando que você tenha uma compreensão abrangente do tema. Durante o módulo, você será apresentado aos fundamentos dessas áreas, entendendo sua importância e relevância no atual cenário digital.

Ao completar este módulo, você estará apto(a) a reconhecer os princípios básicos de privacidade, compreender os fundamentos da segurança da informação e identificar as principais ameaças e vulnerabilidades presentes no ambiente cibernético. Ao adquirir esses conhecimentos, você estará preparado(a) para tomar decisões informadas e estratégicas em relação à segurança cibernética, contribuindo para a proteção de informações sensíveis e a preservação da integridade dos sistemas digitais da sua organização.

Objetivo Geral da Capacitação

Capacitar o público-alvo para obtenção de conhecimento em privacidade e segurança cibernética; contribuir para o desenvolvimento e implementação de medidas protetivas no âmbito dos órgãos e entidades públicas, e também das instituições privadas, na aplicação dos Controles de Segurança Críticos (Controles CIS), mais especificamente CIS Controls versão 8, que foram desenvolvidos pelo Center for Internet Security (CIS).

Unidade 1: O que é a Era Digital?

Objetivo de aprendizagem

Reconhecer os principais conceitos de privacidade, segurança da informação e segurança cibernética

1.1 Privacidade



Videoaula: [Privacidade](#)

No contexto da segurança da informação e segurança cibernética, a privacidade desempenha um papel fundamental na proteção dos dados pessoais e confidenciais. Ela se refere ao direito das pessoas de controlarem suas informações pessoais e decidirem como elas são coletadas, armazenadas, usadas e compartilhadas. A privacidade no contexto da Constituição brasileira é protegida como um direito fundamental:



Art. 5º - X - são invioláveis a intimidade, a vida privada, a honra e a imagem das pessoas, assegurando o direito a indenização pelo dano material ou moral decorrente de sua violação.

Esse dispositivo constitucional garante o respeito à intimidade, à vida privada, à honra e à imagem das pessoas. Isso significa que cada indivíduo tem o direito de não ter sua privacidade invadida, seja por ações de terceiros, seja por ações do Estado.



SAIBA MAIS

A legislação também estabelece garantias que estão relacionadas à privacidade:

Sigilo das correspondências, das comunicações telegráficas, de dados e das comunicações telefônicas, nos termos da lei (artigo 5º, inciso XII);

Proteção ao sigilo da fonte de informações jornalísticas (artigo 5º, inciso XIV);

Proteção contra a utilização de informações obtidas de forma ilícita ou abusiva (artigo 5º, inciso LVI); e

Direito ao esquecimento, quando a imagem ou informações pessoais ultrapassam os limites do interesse público ou causam prejuízos à pessoa (jurisprudência consolidada pelo Supremo Tribunal Federal).

As garantias estabelecidas na legislação têm como objetivo preservar a privacidade dos indivíduos, protegendo sua intimidade, sua vida privada, sua honra e sua imagem. Sendo assim, elas estabelecem a responsabilidade de reparação em caso de violação desses direitos.

É importante ressaltar que a Constituição brasileira é uma fonte para a legislação específica de proteção de dados pessoais, como a Lei Geral de Proteção de Dados (LGPD), que complementa e detalha as disposições constitucionais, estabelecendo regras para o tratamento de dados pessoais no país.



SAIBA MAIS

Sobre a Lei Geral de Proteção de Dados (LGPD) [clique aqui](#).

No contexto da Segurança Cibernética, a proteção da privacidade envolve medidas para prevenir o acesso não autorizado às informações corporativas e pessoais, bem como a implementação de controles adequados para proteger a identidade dos usuários e evitar a divulgação não autorizada de dados.

Medidas de segurança cibernética podem ser adotadas para assegurar a privacidade dos dados, a saber:

Criptografia: utilize algoritmos criptográficos para codificar as informações de modo que só possam ser decodificadas por usuários autorizados com a chave criptografada para proteger os dados em trânsito e em repouso;

Controles de acesso: implemente controles de acesso rigorosos para garantir que apenas pessoas autorizadas possam acessar os dados pessoais. Compreende a autenticação de dois fatores, senhas fortes, controle de privilégios e restrição de acesso baseada em funções;

Políticas de retenção de dados: estabeleça políticas claras de retenção de dados para determinar por quanto tempo os dados devem ser mantidos e quando devem ser permanentemente excluídos. Essas políticas ajudam a minimizar o risco de retenção excessiva e o acesso indevido a dados desnecessários;

Monitoramento e detecção de ameaças: implemente soluções para identificar atividades suspeitas e possíveis violações de privacidade. Isso pode incluir a utilização de sistemas de gerenciamento de informações e eventos de segurança (SIEM) e a análise de logs e registros de eventos;

Treinamento e conscientização dos funcionários: eduque e treine os funcionários sobre as melhores práticas de segurança cibernética e a importância da proteção da privacidade. Essas ações podem incluir boas práticas para identificar phishing, usar de forma adequada as senhas, os dispositivos móveis e ter responsabilidade ao lidar com dados corporativos e pessoais;

Avaliação de fornecedores e parcerias: implemente medidas adequadas de segurança cibernética e proteção da privacidade nos contratos com terceiros;

Privacidade por design: agregue a privacidade ao desenvolver novos sistemas e aplicativos, seguindo o princípio de "privacidade por design", considerando os requisitos de privacidade em todas as etapas do desenvolvimento, desde a coleta até o descarte dos dados; e

Conformidade com regulamentações: esteja ciente das regulamentações e leis de proteção de dados aplicáveis, como a LGPD no Brasil, e certifique-se de estar em conformidade com as exigências legais em relação à privacidade e segurança dos dados.

É importante adotar uma abordagem em camadas, combinando várias técnicas e soluções para fornecer uma proteção abrangente aos dados pessoais. Em resumo, a privacidade no contexto da segurança busca preservar a confidencialidade, a integridade e a disponibilidade dos dados, assegurando que as informações sejam tratadas com o devido respeito e proteção, reduzindo os riscos de exposição e uso indevido. A privacidade é essencial para garantir a confiança e a integridade dos sistemas e redes, desempenha papel fundamental na proteção dos pessoais e confidenciais.

1.2 Segurança da Informação - SI



Videoaula: [Segurança da Informação](#)

Com a crescente dependência da tecnologia e a interconexão global, a Segurança da Informação (SI) passou a ser um aspecto essencial para indivíduos, empresas e governos. A SI é fundamental para a proteção de dados e informações que trafegam por toda a rede online, em um mundo interligado pela Internet (ABNT ISO/IEC 27002:2022). As boas práticas alinhadas com as políticas, normas e procedimentos de SI são ações que devem ser utilizadas em conjunto com as medidas técnicas.

A SI é um processo de proteção dos dados e informações das ameaças a sua confidencialidade, integridade, disponibilidade e autenticidade. É uma área do conhecimento com foco na proteção dos **ativos de informação** contra acessos não autorizados, mudanças indevidas ou sua indisponibilidade (SÊMOLA, 2003; BEAL, 2005).



DESTAQUE

O Glossário do Gabinete de Segurança Institucional da Presidência da República estabelece que a SI são ações que tem como objetivo viabilizar e assegurar a disponibilidade, a integridade, a confidencialidade e a autenticidade das informações.

Ativos de informação: meios de armazenamento, transmissão e processamento da informação, equipamentos necessários a isso, sistemas utilizados para tal, locais onde se encontram esses meios, recursos humanos que a eles têm acesso e conhecimento ou dado que tem valor para um indivíduo ou organização (GABINETE DE SEGURANÇA INSTITUCIONAL - GLOSSÁRIO, 2022).

Em um contexto para proteção dos ativos da informação contra ameaças a SI considerada como princípios a (SIEWERT, 2008):

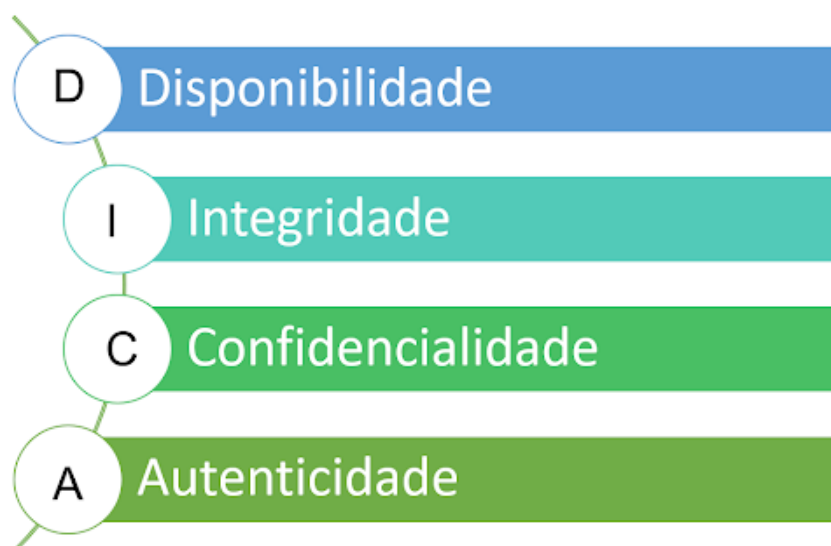
Disponibilidade: garante que os dados e informações estejam disponíveis e acessíveis para os usuários autorizados quando necessário. Sendo assim, se faz necessário a implementação de medidas para assegurar a continuidade dos serviços e minimizar interrupções não planejadas;

Integridade: garante a precisão e a integridade dos dados e informações, assegurando que não sejam alteradas indevidamente durante o armazenamento, o processamento ou a transmissão. Para tanto, se faz necessário implementar medidas de proteção para impedir modificações não autorizadas, erros acidentais ou intencionais e mecanismos que possam comprometer a integridade de dados e informações;

Confidencialidade: garante que os dados e informações estejam acessíveis exclusivamente para os usuários que têm autorização. Com isso, se faz necessário a implementação de controles de acesso com um conjunto de procedimentos, recursos e meios utilizados para conceder ou bloquear o acesso aos recursos computacionais; e

Autenticidade: garante a autenticidade dos dados e informações, bem como a identidade das partes nas trocas de dados e informação. Com isso, se faz necessário implementar mecanismos para assegurar que as interações digitais sejam confiáveis e seguras.

A IN01 do GSI menciona no seu Art. 2º sobre a Estrutura de Gestão da Segurança da Informação nos órgãos e nas entidades da administração pública federal. A gestão da SI demanda ações para assegurar a disponibilidade, a integridade, a confidencialidade e a autenticidade da informação contexto da Administração Pública Federal. [Clique aqui.](#)



Princípios da Segurança da Informação.

Fonte: Adaptado de MACHADO (2014)

Os mecanismos de SI apresentados na sequência, podem ser implementados em diferentes estágios, para assegurar os princípios citados, possibilitando a proteção adequada dos ativos de informação. A prioridade de implementação dos mecanismos de Segurança da Informação (SI) varia dependendo das necessidades específicas de uma organização, do ambiente em que opera e das ameaças que enfrenta. No entanto, é possível estabelecer uma abordagem geral que considera a importância relativa de cada mecanismo, a saber:

Avaliação de Riscos: ao iniciar uma implementação de recursos tecnológicos, é essencial realizar uma avaliação de riscos para identificar as ameaças e vulnerabilidades específicas que afetam a organização. Essa tarefa ajuda a priorizar os mecanismos de acordo com os riscos mais iminentes e críticos

Menor Privilégio: implementar o menor privilégio deve ter como foco limitar o acesso e as permissões de usuários, programas e processos aos recursos de um sistema computacional apenas ao que é essencialmente necessário para realizar tarefas específicas. Limitar os privilégios dos usuários aos sistemas minimiza o potencial de abuso, limita os danos em caso de violação e diminui a superfície de ataque

Segurança em Camadas: estabelecer uma estratégia de segurança em camadas é uma prioridade, pois isso cria uma defesa robusta e abrangente. Com isso, incluir a implementação de *firewalls*, sistemas de detecção e prevenção de intrusões, autenticação multifator e outros controles em várias camadas da infraestrutura passa a ser um requisito tecnológico essencial



DICA

Firewall: ferramenta para evitar acesso não autorizado, tanto na origem quanto no destino, a uma ou mais redes. Podem ser implementados por meio de hardware ou software, ou por meio de ambos. Cada mensagem que entra ou sai da rede passa pelo firewall, que a examina a fim de determinar se atende ou não os critérios de segurança especificados (GABINETE DE SEGURANÇA INSTITUCIONAL – GLOSSÁRIO, 2022)

Criptografia: implementar criptografia é fundamental para proteger a confidencialidade dos dados. Essa técnica tem foco na transformação de dados em formato de texto cifrado, o qual somente usuários autorizados podem ler e obter acesso aos dados originais. A transformação em um texto cifrado, conhecido como criptografado, é realizada com o uso

de uma chave de cifragem e procedimentos computacionais, para que somente os detentores da chave de decifragem possam ler no formato original o texto criptografado



SAIBA MAIS

Criptografia: Conheça o Guia de Requisitos Mínimos de Privacidade e Segurança da Informação para Aplicações Web – Item 3.2.6.
[Clique aqui.](#)

Políticas de Segurança da Informação: estabelecer a política de segurança da informação de forma clara e com o patrocínio da alta direção da organização. A política deve definir diretrizes, critérios e suporte técnico-administrativo essenciais à implementação da SI, bem como orientar o comportamento dos usuários para o uso apropriado dos recursos de tecnologia da informação;

Política Nacional de Segurança da Informação: dispõe sobre a governança da segurança da informação com a finalidade de assegurar a disponibilidade, a integridade, a confidencialidade e a autenticidade da informação a nível nacional. [Disponível aqui.](#)

Treinamento e Conscientização: estruturar programas de treinamento e conscientização para garantir que todos os funcionários compreendam a importância da SI e possam reconhecer ameaças comuns;

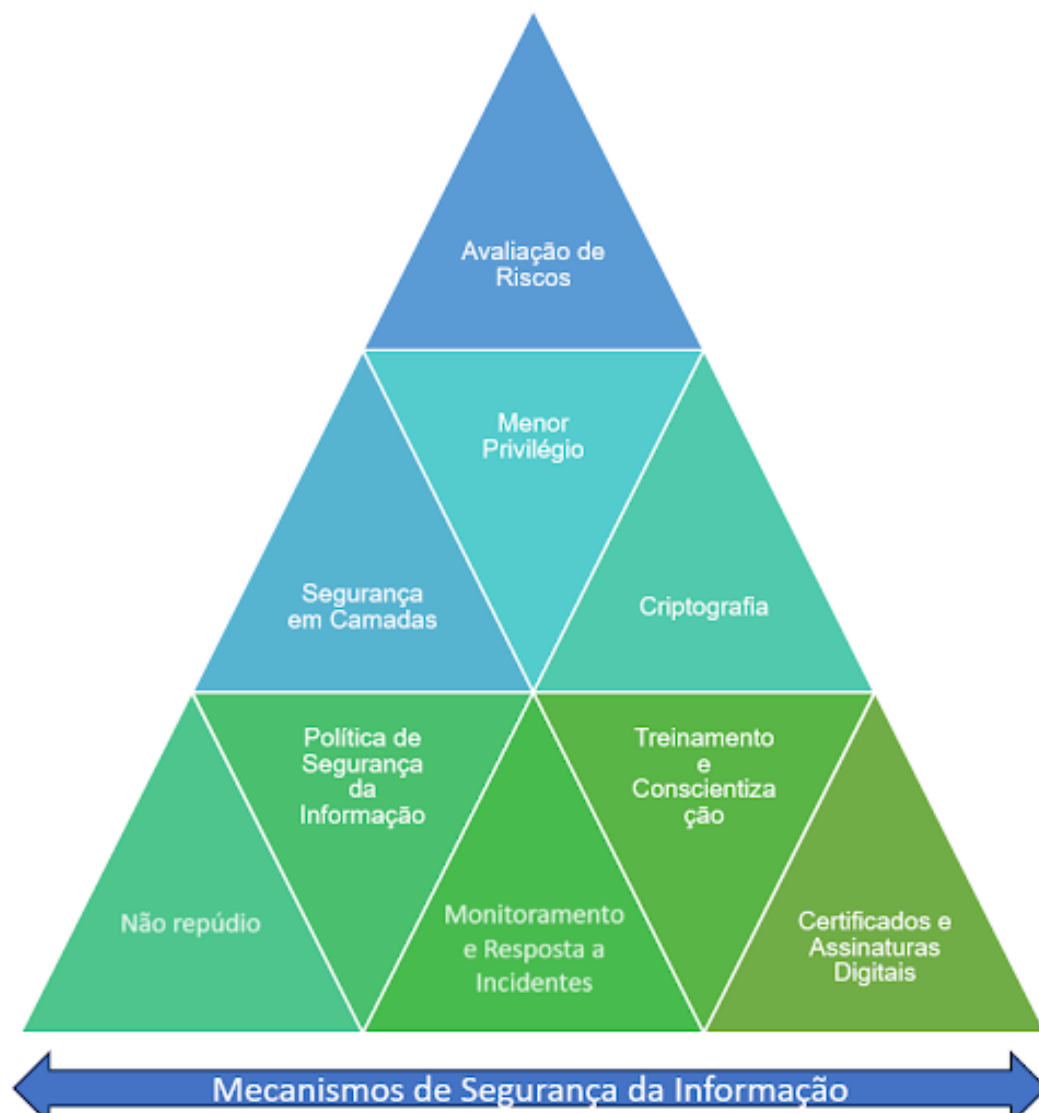
Monitoramento e Resposta a Incidentes: implementar o monitoramento do ambiente computacional para apoiar o plano de resposta a incidentes, Sendo assim, a organização terá possibilidade de monitorar, gerenciar e atuar de forma eficaz em eventuais ataques cibernéticos quando ocorrerem, minimizando o impacto para assegurar a continuidade do negócio;

Não Repúdio, Certificados Digitais e Assinaturas Digitais: estruturar esses mecanismos tendo como foco as transações e comunicações críticas das organizações. São ações que podem ser implementados à medida que a organização começa a operar em níveis mais avançados de segurança;



SAIBA MAIS

Sobre o Certificado Digital, [clique aqui.](#)



Mecanismos de Segurança da Informação.

Fonte: Adaptado de <https://webinsider.com.br/2014/04/21/itil-e-a-seguranca-da-informacao-parte-i/>, (2014)

A SI é domínio de conhecimento com foco na proteção dos ativos de informação contra acessos não autorizados, alterações indevidas e interrupções inesperadas. Com isso, a implementação detalhada dos princípios como disponibilidade, integridade, confidencialidade e autenticidade é essencial para estruturar um ambiente digital seguro e confiável, enquanto a adoção estratégica de mecanismos de SI citados na Figura 2, ajuda estruturar um roteiro para fortalecer as medidas técnicas **para a proteção dos ativos de informação**, na busca da segurança cibernética dos ativos informacionais.

1.3 Segurança Cibernética



Videoaula: [Segurança Cibernética](#)

A Segurança Cibernética busca implementar ações voltadas para a segurança de operações, visando garantir que os sistemas de informação sejam capazes de resistir a eventos no espaço cibernético, capazes de comprometer a disponibilidade, a integridade, a confidencialidade e a autenticidade dos dados armazenados, processados ou transmitidos e dos serviços que esses sistemas ofereçam ou tornem acessíveis (GABINETE DE SEGURANÇA INSTITUCIONAL – GLOSSÁRIO, 2022)

No contexto dos CIS Controls, a segurança cibernética refere-se à implementação de um conjunto de práticas e medidas de segurança para proteger sistemas de tecnologia da informação e infraestruturas críticas contra ameaças cibernéticas. Os CIS Controls são um conjunto de diretrizes amplamente reconhecidas e aceitas que visam melhorar a postura de segurança cibernética de organizações e instituições (Center for Internet Security, 2023).



DESTAQUE

A Secretaria de Assuntos Estratégicos da Presidência da República define que a segurança cibernética busca a proteção dos ativos de informação, bem como assegurar o uso adequado dos ativos de informação estratégicos no contexto das infraestruturas críticas de informação (BRASIL, 2011).

O Ministério da Defesa aborda a Defesa Cibernética como um conjunto de ações defensivas, de busca e ofensivas, no contexto de um planejamento militar, realizadas no espaço cibernético. Essas ações buscam proteger os sistemas de informações do Estado brasileiro (BRASIL, 2010).

As práticas básicas de segurança no espaço cibernético, segundo a ABNT ISO/IEC 27032:2023, fornecem as diretrizes para aperfeiçoar o estado de segurança cibernética (ABNT, 2023). As atividades das melhores práticas de segurança do CIS Controls constituem um conjunto de ações prescritivas e priorizadas para proteger sistemas de tecnologia da informação contra ameaças cibernéticas.

Os CIS Controls são organizados em Basic Controls para gerenciar os ativos de informação e para monitorar e gerenciar as vulnerabilidades; Foundational Controls para recuperação de dados, para gestão de acesso e para resposta aos ataques cibernéticos; *Organizational Controls* para implementar programas de formação e conscientização sobre segurança cibernética no contexto organizacional, para estruturar um plano de resposta a incidentes de segurança na organização, para implementar a gestão de mudança e o planejamento de continuidade de negócios. A Figura 3 apresenta os controles por categoria.



CIS Controls.

Fonte: Adaptado de CENTER FOR INTERNET SECURITY (2023).

Estratégia Nacional de Segurança Cibernética: estabelece objetivos estratégicos que buscam nortear as ações estratégicas do País em segurança cibernética, e representam macrodiretrizes basilares para que o setor público, o setor produtivo e a sociedade possam usufruir de um espaço cibernético resiliente, confiável, inclusivo e seguro. Os objetivos estratégicos, são:

1. Tornar o Brasil mais próspero e confiável no ambiente digital;
2. Aumentar a resiliência brasileira às ameaças cibernéticas; e

3. Fortalecer a atuação brasileira em segurança cibernética no cenário internacional.

[Disponível aqui](#)

1.4 Glossário de Segurança da Informação

A portaria do Gabinete de Segurança Institucional da Presidência da República No. 33 de 18 de outubro de 2023 resolve aprovar o Glossário de Segurança da Informação. A portaria No. 33 revoga a portaria No. 93 de 26 de setembro de 2019. [Acesse o link da portaria N° 33.](#)



DESTAQUE

O Glossário de Segurança da Informação está disponível no Site do Gabinete de Segurança Institucional da Presidência da República. [Acesse aqui](#) para navegar pelos termos definidos no Glossário.

PORTARIA GSI/PR N° 93, DE 18 DE OUTUBRO DE 2021

Site do Glossário de Segurança da Informação.

Fonte: Gabinete de Segurança Institucional da Presidência da República (2023).

O Glossário de Segurança da Informação do Gabinete de Segurança Institucional busca estruturar conceitos técnicos no contexto da SI e segurança cibernética de forma padronizada para facilitar a comunicação eficaz das partes interessadas que desempenham funções na área de segurança do ambiente digital.

Referências

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27002:2022: **Segurança da informação, segurança cibernética e proteção à privacidade - Controles de segurança da informação**. Rio de Janeiro: ABNT, 2022.

BEAL, A. **Segurança da Informação**: princípios e melhores práticas para a proteção dos ativos de informação nas organizações. Atlas, 2005.

BRASIL. **Constituição da República Federativa do Brasil, 1988**. Disponível em: http://www.planalto.gov.br/ccivil_03/constituicao/constituicao.htm. Acesso em: 15 de agosto de 2023.

_____. **Desafios estratégicos para segurança e defesa cibernética**. Secretaria de Assuntos Estratégicos da Presidência da República. Organizadores: Otavio Santana Rego Barros, Ulisses de Mesquita Gomes, Whitney Lacerda de Freitas. Brasília, 2011.

_____. **Ministério da Defesa**. 2010. Disponível em: www.defesa.gov.br/

CENTER FOR INTERNET SECURITY, **CIS Controls**, Disponível em: <https://www.cisecurity.org/>. Acesso em: 15 de agosto de 2023.

GABINETE DE SEGURANÇA INSTITUCIONAL. **Glossário de Segurança da Informação**. 2022. Disponível em: <https://www.gov.br/gsi/pt-br/assuntos/dsi/glossario-de-seguranca-da-informacao-1>. Acesso em: 15 de agosto de 2023.

MACHADO, FELIPE NERY RODRIGUES. **Segurança da informação**: princípios e controle de ameaças. Saraiva Educação SA, 2014.

MANDARINO, R. **Um Estudo sobre a Segurança e a Defesa do Espaço Cibernético Brasileiro**. Universidade de Brasília (UnB). Departamento de Ciência da Computação – DCE. p. 29. Brasília. Jun. 2009.

SÊMOLA, M. **Gestão da Segurança da Informação**: uma visão executiva. Campus. 2003.

SIEWERT, V. C. **A Constante Evolução da Segurança da Informação**. 2008.

2 Fundamentação e estruturação dos controles

Bem-vindo(a) ao Módulo 2

O objetivo deste módulo é apresentar as normas legais de conformidade, relacionadas com a privacidade, Segurança da Informação e Segurança Cibernética.

Ao completar este módulo, você terá conhecimento sobre Leis, Decretos, Portarias, Normas e Resoluções relacionadas com a Privacidade, Segurança da Informação e Segurança Cibernética. O Módulo 2 apresenta uma visão da Estratégia de Segurança Cibernética, Política Nacional de Segurança da Informação e Estratégia de Governo Digital.

Unidade 1: Abordagem de controles e implementação de cibersegurança

Objetivo de aprendizagem

Conhecer as normas legais de conformidade, relacionadas com a privacidade, segurança da informação e segurança cibernética

1.1 Leis

A crescente dependência das organizações em relação à tecnologia da informação e o aumento das ameaças cibernéticas demandam a necessidade premente de garantir a segurança dos sistemas e dados digitais. Nesse cenário, as leis e regulamentações relacionadas à Segurança Cibernética emergem como fundamentais para estabelecer um ambiente seguro e confiável para o armazenamento, processamento e transmissão de informações.

À medida que a sociedade avança para uma era digital, a proteção contra-ataques cibernéticos e o cumprimento das melhores práticas de segurança tornaram-se imperativos para proteger tanto os interesses das organizações quanto a privacidade dos indivíduos.

Este contexto ressalta a importância de entender e conhecer as leis relacionadas com a Segurança Cibernética, suas implicações e o seu papel essencial na construção de um ecossistema digital resiliente e protegido contra ameaças cada vez mais sofisticadas.



Lei nº 9.983, de 14 de julho de 2000.

Altera o Decreto-Lei nº 2.848, de 7 de dezembro de 1940 - Código Penal e dá outras providências

Lei nº 12.527, de 18 de novembro de 2011.

Regula o acesso a informações previsto nº inciso XXXIII do art. 5º, no inciso II do § 3º do art. 37 e no § 2º do art. 216 da Constituição Federal; altera a Lei nº 8.112, de 11 de dezembro de 1990; revoga a Lei nº 11.111, de 5 de maio de 2005, e dispositivos da Lei nº 8.159, de 8 de janeiro de 1991; e dá outras providências

Lei nº 12.737, de 30 de novembro de 2012.

Dispõe sobre a tipificação criminal de delitos informáticos; altera o Decreto-Lei nº 2.848, de 7 de dezembro de 1940 - Código Penal; e dá outras providências

As Leis.

Fonte: Adaptado de Gabinete de Segurança Institucional da Presidência da República (2020), Disponível em: <https://www.gov.br/gsi/pt-br/ssic/legislacao>. acesso em: 15 de agosto de 2023.



SAIBA MAIS

Conheça os detalhes de cada lei. [Lei nº 9.983](#), de 14 de julho de 2000, [Lei nº 12.527](#), de 18 de novembro de 2011 e [Lei nº 12.737](#), de 30 de novembro de 2012.

No quadro a seguir estão listadas a Lei correlatas.

Lei	Ementa
Lei nº 13.790 , de 14 de agosto de 2018	Esta Lei dispõe sobre o tratamento de dados pessoais, inclusive nos meios digitais, por pessoa natural ou por pessoa jurídica de direito público ou privado, com o objetivo de proteger os direitos fundamentais de liberdade e de privacidade e o livre desenvolvimento da personalidade da pessoa natural. (LGPD)
Lei nº 12.965 , de 23 de abril de 2014.	Esta Lei estabelece princípios, garantias, direitos e deveres para o uso da internet no Brasil e determina as diretrizes para atuação da União, dos Estados, do Distrito Federal e dos Municípios em relação à matéria.

Leis correlatas.

Fonte: Gabinete de Segurança Institucional, 2023.

O conhecimento das leis relacionadas à Segurança da Informação e Segurança Cibernética é necessário para implementar ações de controles de segurança considerando uma base legal. Portanto, ao ter o conhecimento das leis citadas no curso é fundamental para que as boas práticas de segurança da sua organização estejam alinhadas com a legislação relacionada com o tema.

1.2 Decretos

Os decretos são fundamentais para criar um ambiente regulatório que proporcione diretrizes claras e exigências específicas para as organizações e entidades, sejam elas públicas ou privadas. Eles visam estabelecer um padrão mínimo de medidas de Segurança Cibernética que abrangem desde a proteção de dados e informações até a salvaguarda de infraestruturas críticas. A legislação incentiva a adoção de melhores práticas de Segurança Cibernética, como a implementação de firewalls, detecção de intrusões, criptografia e planos de resposta a incidentes.

Ao estabelecer um quadro regulatório sólido, esses decretos podem proporcionar um ambiente mais seguro para investimentos e inovação, uma vez que as partes interessadas têm a garantia de que os riscos cibernéticos estão sendo abordados de maneira eficaz. Os decretos relacionados à Segurança Cibernética desempenham um papel crucial na proteção da sociedade moderna contra as ameaças cibernéticas em constante evolução. Eles são uma resposta necessária para preservar a integridade dos sistemas digitais, proteger os dados e informações e promover um ambiente confiável e seguro para todas as partes envolvidas.

O quadro 2 a seguir lista os decretos regulatórios

Decretos	Ementa
Decreto nº 10.849 , de 28 de outubro de 2021	Altera o Decreto nº 9.637, de 26 de dezembro de 2018, para dispor sobre a composição do Comitê Gestor da Segurança da Informação.
Decreto nº 10.748 , de 16 de julho de 2021	Institui a Rede Federal de Gestão de Incidentes Cibernéticos.
Decreto nº 10.641 , de 2 de março de 2021	Política Nacional de Segurança da Informação, dispõe sobre a governança da segurança da informação, e altera o Decreto nº 2.295, de 4 de agosto de 1997, que regulamenta o disposto no art. 24, caput, inciso IX, da Lei nº 8.666, de 21 de junho de 1993, e dispõe sobre a dispensa de licitação nos casos que possam comprometer a segurança nacional.
Decreto nº 10.222 , de 5 de fevereiro de 2020	A presente Estratégia Nacional de Segurança Cibernética - E-Ciber é a orientação manifesta do Governo federal à sociedade brasileira sobre as principais ações por ele pretendidas, em termos nacionais e internacionais, na área da Segurança Cibernética e terá validade no quadriênio 2020-2023.
Decreto nº 9.832 , de 12 de junho de 2019	Altera o Decreto nº 9637, de 26 de dezembro de 2018, e o Decreto nº 7.845, de 14 de novembro de 2012, para dispor sobre o Comitê Gestor da Segurança da Informação.
Decreto nº 9.637 , de 26 de dezembro de 2018	Institui a Política Nacional de Segurança da Informação, dispõe sobre a governança da segurança da informação, e altera o Decreto nº 2.295, de 4 de agosto de 1997, que regulamenta o disposto no art. 24, caput, inciso IX, da Lei nº 8.666, de 21 de junho de 1993, e dispõe sobre a dispensa de licitação nos casos que possam comprometer a segurança nacional.
Decreto nº 7.845 , de 14 de novembro de 2012	Regulamenta os procedimentos para credenciamento de segurança e tratamento de informação classificada em qualquer grau de sigilo, e dispõe sobre o Núcleo de Segurança e Credenciamento.
Decreto nº 7724 , de 16 de maio de 2012	Regulamenta a Lei nº 12.527, de 18 de novembro de 2011, que dispõe sobre o acesso a informações previsto no inciso XXXIII do caput do art 5º, no inciso II do § 3º do art. 37 e no § do art. 216 da Constituição.

Decretos.

Fonte: Gabinete de Segurança Institucional, 2023

Os decretos relacionados à Segurança da Informação e Segurança Cibernética possibilitam estabelecer um quadro legal e regulatório no contexto da proteção dos dados, informações e sistemas no ambiente digital. Esses instrumentos legais promovem uma cultura de segurança para mitigar as crescentes ameaças cibernéticas.

1.3 Portarias

No contexto da Segurança Cibernética, as portarias desempenham um papel essencial como instrumentos regulatórios e orientativos que complementam as leis e regulamentações mais abrangentes. Elas são diretrizes específicas emitidas por autoridades competentes ou órgãos reguladores para estabelecer procedimentos, requisitos técnicos e padrões a serem seguidos pelas organizações e entidades no que diz respeito à proteção de sistemas, dados e informações.

As portarias, ao detalharem requisitos específicos, contribuem para a concretização das diretrizes gerais definidas em leis e regulamentações mais amplas, e estabelecem procedimentos operacionais, por exemplo protocolos de segurança, especificações técnicas, mecanismos eficazes de Segurança Cibernética. Isso pode incluir requisitos para auditorias regulares, planos de resposta a incidentes, práticas de autenticação forte, políticas de gerenciamento de acessos e muito mais.

Elas estabelecem mecanismos de acompanhamento e atualização em um cenário onde a tecnologia e as ameaças estão em constante mudança. Segurança Cibernética considerando novos riscos e novas soluções tecnológicas desenvolvidas. Asseguram que as organizações tenham orientações detalhadas para implementar medidas de proteção eficazes, se adaptar a novas ameaças e contribuir para um ambiente digital seguro e resiliente.

Destaca-se as Portarias:



SAIBA MAIS

A Portaria nº 120, de 21 de dezembro de 2022, aprova o Plano de Gestão de Incidentes Cibernéticos para a administração pública federal. Saiba mais [clicando aqui](#).

A Portaria nº 93 GSI/PR, de 18 de outubro de 2021 aprova o Glossário de Segurança da Informação. Veja [clicando aqui](#).

As portarias asseguram que as organizações tenham orientações detalhadas para implementar medidas de proteção eficazes, se adaptar a novas ameaças e contribuir para um ambiente digital seguro e resiliente. Sendo assim, elas podem esclarecer pontos técnicos, requisitos específicos e processos para implementar medidas de segurança, garantindo que as organizações compreendam as suas necessidades.

1.4 Normas

As normas publicadas pelo Governo Federal no contexto da Segurança Cibernética têm como fonte o Gabinete de Segurança Institucional. Essas normas abordam um conjunto de diretrizes, regulamentos e procedimentos que orientam as atividades e operações de segurança da informação a serem realizadas pelos órgãos da Administração Pública Federal.

As normas publicadas pela Administração Pública Federal em relação à Segurança Cibernética são estruturadas para assegurar a confidencialidade, integridade e disponibilidade dos dados, informações e sistemas das operações governamentais digitais, bem como fomentar a confiança da sociedade em relação à gestão segura das informações governamentais e resiliência para mitigar as ameaças cibernéticas. O quadro 3 apresenta as normas vigentes.

Norma	Ementa
Instrução Normativa GSI nº 1 – Consolidada, de 27 de maio de 2020	Dispõe sobre a Estrutura de Gestão da Segurança da Informação nos órgãos e nas entidades da administração pública federal.
Instrução Normativa GSI nº 2 , 5 de fevereiro de 2013	Dispõe sobre o Credenciamento de segurança para o tratamento de informação classificada, em qualquer grau de sigilo, no âmbito do Poder Executivo Federal.
Instrução Normativa GSI nº 3 , 6 de março de 2013	Dispõe sobre os parâmetros e padrões mínimos dos recursos criptográficos baseados em algoritmos de Estado para criptografia da informação classificada no âmbito do Poder Executivo Federal.
Instrução Normativa GSI nº 4 , 26 de março de 2020	Dispõe sobre os requisitos mínimos de Segurança Cibernética que devem ser adotados no estabelecimento das redes 5G.
Instrução Normativa GSI nº 5 , 30 de agosto de 2021	Dispõe sobre os requisitos mínimos de segurança da informação para utilização de soluções de computação em nuvem pelos órgãos e pelas entidades da administração pública federal.

Instrução Normativa GSI nº 6 – Consolidada 23 de dezembro de 2021	Estabelece diretrizes de segurança da informação para o uso seguro de mídias sociais nos órgãos e nas entidades da administração pública federal.
Instrução Normativa GSI nº 7 - 29 de novembro de 2022	Altera a Instrução Normativa nº 1, de 27 de maio de 2020, do Gabinete de Segurança Institucional da Presidência da República; a Instrução Normativa GSI/PR nº 3, de 28 de maio de 2021; e a Instrução Normativa nº 6, de 23 de dezembro de 2021, do Gabinete de Segurança Institucional da Presidência da República.

Normas.

Fonte: Gabinete de Segurança Institucional, 2023.

Para dar suporte a legislação, existem ainda normas complementares, como apresentado no quadro 4.

Norma Complementar	Ementa
NC nº 01/IN02/NSC/GSIPR , e seus anexos (Anexo A e Anexo B)	Disciplina o Credenciamento de Segurança de Pessoas Naturais, Órgãos e Entidades Públicas e Privadas para o Tratamento de Informações Classificadas. (Publicada no DOU Nº 123, de 28 de junho de 2013 - Seção 1)
NC nº 05/IN01/DSIC/GSIPR	Disciplina a criação de Equipes de Tratamento e Respostas a Incidentes em Redes Computacionais - ETIR nos órgãos e entidades da Administração Pública Federal. (Publicada no DOU Nº 156, de 17 Ago 2009 - Seção 1)
NC nº 08 /IN01/DSIC/GSIPR	Estabelece as Diretrizes para Gerenciamento de Incidentes em Redes Computacionais nos órgãos e entidades da Administração Pública Federal. (Publicada no DOU Nº 162, de 24 Ago 2010 - Seção 1)
NC nº 09 /IN01/DSIC/GSIPR	Estabelece orientações específicas para o uso de recursos criptográficos em Segurança da Informação e Comunicações, nos órgãos ou entidades da Administração Pública Federal (APF), direta e indireta. (Publicada no DOU Nº 134, de 16 Jul 2014 - Seção 1)
NC nº 12 /IN01/DSIC/GSIPR	Estabelece diretrizes e orientações básicas para o uso de dispositivos móveis nos aspectos referentes à Segurança da Informação e Comunicações (SIC) nos órgãos e entidades da Administração Pública Federal (APF), direta e indireta. (Publicada no DOU Nº 30, de 10 Fev 2012 - Seção 1)
NC nº 17 /IN01/DSIC/GSIPR	Estabelece as Diretrizes para as Atividades de Ensino em Segurança da Informação e Comunicações (SIC) nos Órgãos e Entidades da Administração Pública Federal (APF). (Publicada no DOU Nº 68, de 10 Abril 2013 - Seção 1)

NC nº 18 /IN01/DSIC/GSIPR	Estabelece as Diretrizes para as Atividades de Ensino em Segurança da Informação e Comunicações (SIC) nos Órgãos e Entidades da Administração Pública Federal (APF). (Publicada no DOU Nº 68, de 10 Abril 2013 - Seção 1)
NC nº 20 /IN01/DSIC/GSIPR	Estabelece as Diretrizes de Segurança da Informação e Comunicações para Instituição do Processo de Tratamento da Informação nos órgãos e entidades da Administração Pública Federal (APF), direta e indireta. (Publicada no DOU Nº 242, de 15 Dez 2014 - Seção 1)
NC nº 21 /IN01/DSIC/GSIPR	Estabelece as Diretrizes para o Registro de Eventos, Coleta e Preservação de Evidências de Incidentes de Segurança em Redes nos órgãos e entidades da Administração Pública Federal, direta e indireta. (Publicada no DOU Nº 196, de 10 Out 2014 - Seção 1)

Normas Complementares.

Fonte: Gabinete de Segurança Institucional, 2023.

As normas possibilitam a implementação de diretrizes e práticas reconhecidas para a Segurança da Informação e Segurança Cibernética. Elas fornecem um conjunto claro de regras que organizações e profissionais podem seguir para proteger dados, informações e sistemas contra ameaças cibernéticas. Sendo assim, elas representam as melhores práticas para lidar com os desafios da Segurança Cibernética, tornando possível a implementação de medidas adequadas no contexto da segurança.

1.5 Resoluções

O Governo Federal, nas suas atribuições, aprova o Regimento Interno do Comitê Gestor da Segurança da Informação pela Resolução Nº 1, de 11 de setembro de 2019. Acesse a resolução [clikando aqui](#).

1.6 Estratégia Nacional de Segurança Cibernética

A Estratégia Nacional de Segurança Cibernética (E-Ciber) é uma orientação do Governo federal à sociedade brasileira sobre as principais ações por ele pretendidas, em termos nacionais e internacionais, na área da segurança cibernética (GSI – E-Ciber, 2020).

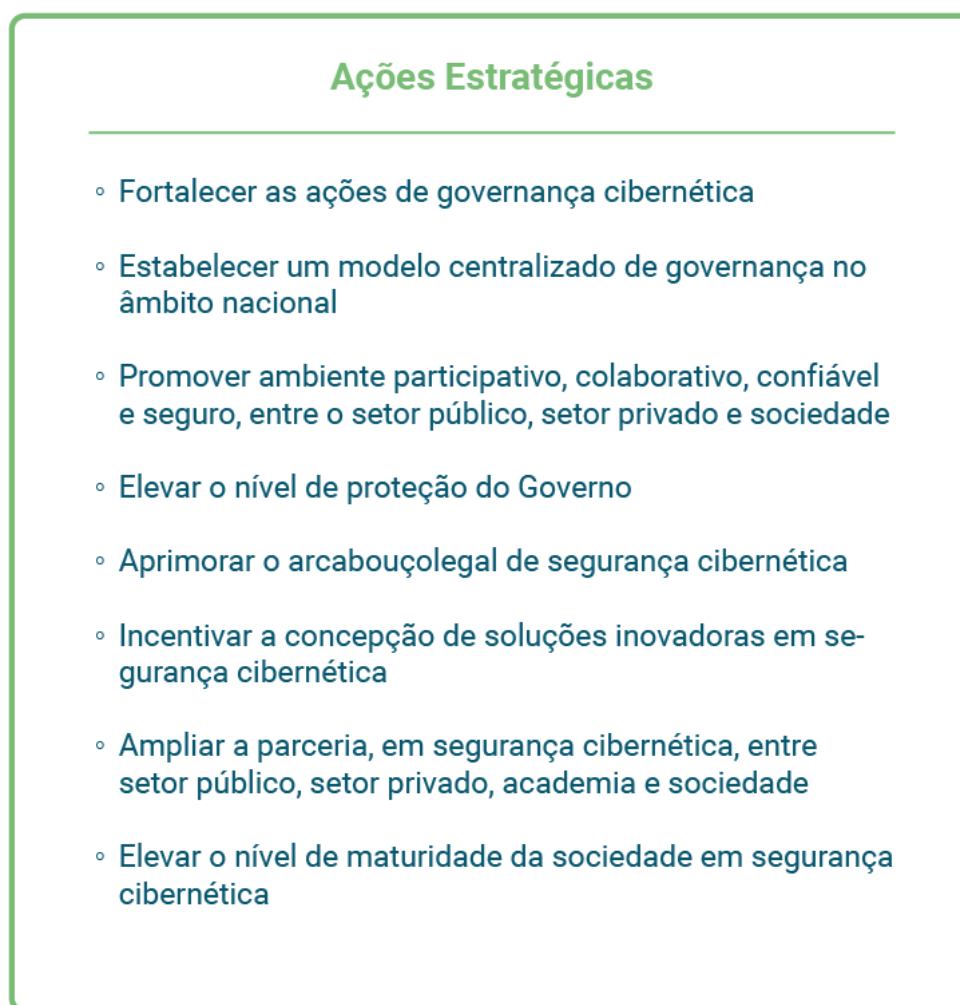
O Decreto nº 9.637, de 2018, menciona, em seu art. 6º, que a Estratégia Nacional de Segurança da Informação busca contemplar a Segurança Cibernética, a Defesa Cibernética, a Segurança das Infraestruturas Críticas, à Segurança da Informação sigilosa e a proteção contra vazamento de dados (GSI – E-Ciber, 2020).



SAIBA MAIS

■ [Clique aqui](#) para realizar a leitura da E-Ciber.

A figura a seguir apresenta as ações estratégicas de segurança da informação.



Ações estratégicas.

Fonte: Adaptado de Gabinete de Segurança Institucional da Presidência da República – E-Ciber (2020).

Sendo assim, a E-Ciber foi elaborada com a coordenação do Gabinete de Segurança Institucional. O trabalho foi realizado com a participação de organizações do setor público, privado e da academia. Foi utilizada uma metodologia bottom-up, considerando as conclusões dos subgrupos participantes da elaboração, em avaliação comparativa sobre estratégias correlatas de países que já tinham publicado as suas estratégias (GSI – E-Ciber, 2020).

1.7 Política Nacional de Segurança da Informação

A Política Nacional de Segurança da Informação (PNSI) tem a finalidade de assegurar a disponibilidade, a integridade, a confidencialidade e a autenticidade da informação a nível nacional (GSI - PNSI, 2018).

Os princípios da PNSI, são (GSI - PNSI, 2018):

- Soberania nacional;
- Respeito e promoção dos direitos humanos e das garantias fundamentais, em especial a liberdade de expressão, a proteção de dados pessoais, a proteção da privacidade e o acesso à informação
- Visão abrangente e sistêmica da segurança da informação;
- Responsabilidade do País na coordenação de esforços e no estabelecimento de políticas, estratégias e diretrizes relacionadas à segurança da informação;
- Intercâmbio científico e tecnológico relacionado à segurança da informação entre os órgãos e as entidades da administração pública federal;
- Preservação do acervo histórico nacional;
- Educação como alicerce fundamental para o fomento da cultura em segurança da informação;
- Orientação à gestão de riscos e à gestão da segurança da informação;
- Prevenção e tratamento de incidentes de segurança da informação;
- Articulação entre as ações de segurança cibernética, de defesa cibernética e de proteção de dados e ativos da informação;
- Dever dos órgãos, das entidades e dos agentes públicos de garantir o sigilo das informações imprescindíveis à segurança da sociedade e do Estado e a inviolabilidade da intimidade da vida privada, da honra e da imagem das pessoas;
- Conhecimento para o acesso à informação sigilosa, nos termos da legislação;
- Consentimento do proprietário da informação sigilosa recebida de outros países, nos casos dos acordos internacionais;

- Cooperação entre os órgãos de investigação e os órgãos e as entidades públicos no processo de credenciamento de pessoas para acesso às informações sigilosas;
- Integração e cooperação entre o Poder Público, o setor empresarial, a sociedade e as instituições acadêmicas; e
- Cooperação internacional, no campo da segurança da informação.

Os objetivos da PNSI, são (GSI - PNSI, 2018):

- Contribuir para a segurança do indivíduo, da sociedade e do Estado, por meio da orientação das ações de segurança da informação, observados os direitos e as garantias fundamentais;
- Fomentar as atividades de pesquisa científica, de desenvolvimento tecnológico e de inovação relacionadas à segurança da informação;
- Aprimorar continuamente o arcabouço legal e normativo relacionado à segurança da informação;
- Fomentar a formação e a qualificação dos recursos humanos necessários à área de segurança da informação;
- Fortalecer a cultura da segurança da informação na sociedade;
- Orientar ações relacionadas a:
 - a) segurança dos dados custodiados por entidades públicas;
 - b) segurança da informação das infraestruturas críticas;
 - c) proteção das informações das pessoas físicas que possam ter sua segurança ou a segurança das suas atividades afetada, observada a legislação específica; e
 - d) tratamento das informações com restrição de acesso; e
- Contribuir para a preservação da memória cultural brasileira.



SAIBA MAIS

[Clique aqui](#) para saber mais sobre o PNSI



DICA

[Acesse o E-Ciber](#) do Site do Gabinete de Segurança Institucional para leitura das Leis, Decretos, Portarias, Normas, Resoluções relacionadas com a Segurança Cibernética.

1.8 Estratégia de Governo Digital

A Estratégia de Governo Digital (EGD) para o período de 2020 a 2023 está organizada em princípios, objetivos e iniciativas que nortearão a transformação do governo por meio de tecnologias digitais. A referida estratégia busca oferecer políticas públicas e serviços de melhor qualidade, mais simples, acessíveis a qualquer hora e lugar e a um custo menor para o cidadão (GOVERNO DIGITAL, 2020).

Saiba mais na [Plataforma Governo Digital](#).

Para conhecer a linha do tempo que representa o caminho de atualização da EGD até o seu lançamento para o período de 2024-2027 [clique aqui](#). A referida atualização busca oferecer um Governo Eficiente e Sustentável; Inteligente e Inovador; Centrado no Cidadão e Inclusivo; Confiável e Seguro; Integrado e Colaborativo; bem como Transparente, Aberto e Participativo.

Além disso, [clique aqui](#) para leitura de várias informações da Secretaria de Governo Digital referente ao Programa de Privacidade e Segurança da Informação (PPSI), Framework do Programa de Privacidade e Segurança da Informação, Guias e Modelos, Centro Integrado de Segurança da Informação (CISC Gov.br) e Centro de Excelência em Privacidade e Segurança (CEPS Gov.br), nos quais disponibilizam um conjunto de projetos e processos de adequação nas áreas de privacidade e segurança da informação para apoiar a EGD.

Por fim, a EGD estabelece uma abordagem com foco na forma como os governos prestam serviços, interagem com cidadãos e operam internamente, utilizando as tecnologias digitais de maneira eficiente e eficaz. No contexto da Segurança da Informação e Segurança Cibernética, essa estratégia incorpora medidas de proteção para garantir que os dados e informações utilizadas nas operações governamentais permaneçam seguras no ecossistema digital em constante evolução. A EDG é essencial para garantir a proteção dos dados e informações dos cidadãos, das operações governamentais e das suas infraestruturas críticas. Com isso, permitindo a construção de um governo digital confiável e seguro.

Referências

BRASIL. **Gabinete de Segurança Institucional**. Estratégia de Segurança Cibernética, 2020. Disponível em: <https://www.gov.br/gsi/pt-br/composicao/SSIC/dsic/estrategia-nacional-de-seguranca-cibernetica-e-ciber>. Acesso em: 23 de agosto de 2023.

BRASIL. **Gabinete de Segurança Institucional**. Política Nacional de Segurança da Informação, 2018. Disponível em: https://www.in.gov.br/materia/-/asset_publisher/Kujrw0TZC2Mb/content/id/56970098/do1-2018-12-27-decreto-n-9-637-de-26-de-dezembro-de-2018-56969938. Acesso em: 23 de agosto de 2023.

BRASIL. **Governo Digital**. Secretaria de Governo Digital. Estratégia de Governo Digital, 2020. Disponível em: <https://www.gov.br/governodigital/pt-br/EGD2020/estrategia-de-governo-digital-2020-2022>. Acesso em: 23 de agosto de 2023.

3 Gestão de Segurança da Informação

Bem-vindo(a) ao Módulo 3

O objetivo deste módulo é apresentar os principais fundamentos para uma Política de Segurança da Informação, os conceitos para a Gestão de Riscos e Incidentes de Segurança, bem como ações para sensibilização, conscientização e capacitação no contexto da Segurança da Informação e Segurança Cibernética.

Ao completar este módulo, você terá conhecimento para estruturar uma Política de Segurança da Informação, direcionar e controlar os riscos de privacidade, segurança da informação e cibernética, a fim de adequá-lo aos níveis aceitáveis para o órgão ou entidade e terá habilidades e insights para de fomentar e disseminar a cultura de Segurança da Informação na sua organização.

Unidade 1: Política de Segurança da Informação

Objetivo de aprendizagem

Conhecer os principais fundamentos para publicação de uma Política de Segurança da Informação, a partir da formalização e aprovação por parte da autoridade máxima da instituição, com o objetivo de estabelecer diretrizes, responsabilidades, competências e subsídios para a gestão da segurança da informação.

1.1 Escopo

O escopo de uma Política de Segurança da Informação descreve o objetivo e a abrangência da Política, definindo o limite dentro do qual as ações de segurança da informação serão desenvolvidas no órgão ou na entidade. É um item da política que identifica as áreas específicas que serão foco da política no contexto da organização. O escopo desempenha um papel essencial na definição da extensão das medidas de segurança que serão aplicadas para contemplar as necessidades da organização no que diz respeito à proteção dos ativos de informação. A figura 7 apresenta o escopo da Política de Segurança da Informação

Escopo da Política Nacional de Segurança da Informação

- Indicar claramente quais partes da organização são abrangidas pela política
- Identificar quais tipos de ativos de informação estão sujeitos às medidas de segurança definidas na política
- Especificar quais processos e operações são cobertos pela política. Isso pode envolver desde a coleta e o armazenamento de dados até a transmissão, processamento e descarte.
- Identificar quais usuários e funções da organização estão sujeitos às diretrizes de Segurança da Informação
- Estabelecer as tecnologias e a infraestrutura que fazem parte do escopo da política
- Identificar as regulamentações de conformidade específicas que a organização deve seguir, no contexto das leis de privacidade, regulamentos de setor e boas práticas de segurança
- Garantir que a política seja flexível o suficiente para se adaptar a mudanças na organização

Escopo da Política Nacional de Segurança da Informação.

Fonte: Adaptado de Gabinete de Segurança Institucional da Presidência da República – PNSI (2020).

O escopo de uma política de segurança da informação faz com que os aspectos relevantes da Segurança da Informação sejam abordados de maneira abrangente e eficaz, permitindo estabelecer os limites e as responsabilidades relacionadas à Segurança da Informação para as partes interessadas.

1.2 Conceitos e Definições

Os conceitos e definições relaciona e descreve os conceitos e definições a serem utilizados na Política do órgão ou da entidade que possam gerar dificuldade de interpretação ou ambiguidade, devendo ser utilizadas as definições contidas no Glossário de Segurança da Informação, aprovado pelo Gabinete de Segurança Institucional da Presidência da República.

Uma Política de Segurança da Informação é fundamental para assegurar que as partes interessadas tenham o alinhamento padronizado sobre os termos relacionados com os conceitos e definições mencionados.

A padronização dos termos facilita o entendimento e solução das questões relacionadas com a segurança, passando a ser um instrumento para fomentar a cultura da Segurança da Informação na organização. Quando os colaboradores entendem os riscos e ameaças à segurança da informação, eles podem tomar medidas para se proteger.

A figura 8 na sequência lista quatro benefícios de incluir conceitos e definições em uma política de Segurança da Informação:



Benefícios dos conceitos.

Fonte: Adaptado de Gabinete de Segurança Institucional da Presidência da República (2020).

Ao elaborar uma política de segurança da informação, é importante incluir uma seção dedicada aos conceitos e definições. Essa seção deve ter os principais termos relacionados com os conceitos usados na política, bem como suas definições. Os termos devem ser simples, descritos de forma clara e concisa para o entendimento por parte dos colaboradores.

Na sequência temos exemplos para uma seção de conceitos e definições em uma política de segurança da informação:

Conceitos e Definições:

Confidencialidade: assegura que os dados e/ou informações não estejam disponíveis ou sejam acessados por um usuário ou organização não autorizada ou credenciada;

Integridade: assegura que os dados e/ou informações não foram modificadas ou destruídos de forma acidental ou não autorizada;

Disponibilidade: assegura que os dados e/ou informações estejam acessíveis para uso sobre demanda, pelos usuários ou organização devidamente autorizados;

Autenticidade: assegura que os dados e/ou informações são verdadeiras e não foram falsificadas ou modificadas nas interações digitais, transmitindo a confiança para as partes interessadas.



DICA

Exemplos de definições:

Informações confidenciais: informações que, se divulgadas, causariam danos ou prejuízos à organização.

Vulnerabilidade: fragilidade de um ativo de informação;

Ameaça: conjunto de eventos que tem poder criar um incidente;
Incidente: evento que representa uma ameaça de segurança para os ativos de informação;

Ataque cibernético: uma tentativa de acessar, alterar ou destruir informações de forma não autorizada; e

Segurança da informação: o processo de proteger as informações de uma organização de acesso, uso, divulgação, modificação ou destruição não autorizados.

1.3 Princípios

Os princípios em uma Política de Segurança da Informação funcionam como uma base sólida que moldam a cultura de Segurança da Informação em uma organização. Ao estabelecer princípios bem definidos, a organização comunica seus valores fundamentais em relação à Segurança da Informação, no seu ambiente interno, como no ambiente externo. A figura 9 apresenta os princípios



Princípios da Política de Segurança da Informação.

Fonte: Adaptado de BEAL (2005).

Os princípios oferecem consistência nas ações da organização ao longo do tempo e em diferentes situações. Eles fornecem a base ética, cultural e estratégica necessária para uma política de segurança eficaz, ajudam a evitar abordagens reativas e improvisadas à Segurança da Informação, promovendo uma mentalidade estratégica e de longo prazo. Sendo assim, os princípios são essenciais em um cenário com a dinâmica de novas ameaças cibernéticas no ambiente digital das organizações.

1.4 Diretrizes

As diretrizes em uma Política de Segurança da Informação são instruções claras e específicas estabelecidas por uma organização para assegurar a proteção dos ativos de informação. A definição das diretrizes deve focar na implementação e manutenção de uma postura de segurança robusta e abrangente, considerando as melhores práticas de Segurança da Informação.

As diretrizes devem:

- Orientar de forma clara sobre como abordar uma situação específica ou realizar uma tarefa, ajudando a evitar confusões e ambiguidades;
- Padronizar um conjunto uniforme de práticas e procedimentos, promovendo a consistência e coesão nas operações e decisões;
- Alinhar as ações individuais e coletivas com os objetivos e valores da organização, promovendo uma abordagem unificada e eficiente na tomada de decisão;
- Oferecer orientações sobre melhores práticas e abordagens seguras, as diretrizes podem ajudar a minimizar riscos e erros; e
- Permitir flexibilidade dentro de certos limites, permitindo adaptações à medida que a situação exige, considerando os parâmetros estabelecidos.

Veja o que as diretrizes abrangem:

Tratamento da informação: as diretrizes para o tratamento da informação buscam estabelecer mecanismos e controles como os dados devem ser coletados, processados, armazenados e compartilhados. Elas definem as práticas para garantir a confidencialidade, integridade, disponibilidade e autenticidade das informações, bem como diretrizes para a classificação e processamento dos dados sensíveis;

Segurança física: as diretrizes relacionadas com a segurança física buscam estabelecer medidas para proteger fisicamente os ativos de informação. Isso inclui restrições de acesso a locais críticos, monitoramento por meio de sistemas de segurança, controles de entrada e saída, bem como medidas para prevenir danos causados por fatores ambientais;

Gestão de incidentes: as diretrizes para a gestão de incidentes buscam definir a metodologia a ser seguida em caso de incidentes de segurança, como ataques cibernéticos, vazamentos de dados ou falhas de sistemas. Elas estabelecem as etapas para identificação, resposta, recuperação e análise pós-incidente;

Gestão de ativos: as diretrizes de gestão de ativos buscam determinar como os recursos de tecnologia da informação devem ser inventariados, rastreados, protegidos e descartados ao final de sua vida útil, visando otimizar a utilização dos recursos e minimizar riscos;

Gestão do uso dos recursos digitais: as diretrizes para gestão dos recursos digitais buscam regular o uso das tecnologias disponíveis no ecossistema digital, como por exemplo: a internet, o e-mail, as mídias sociais e a computação em nuvem. Elas definem quais atividades são permitidas, restringidas ou proibidas, a fim de garantir a produtividade e minimizar riscos relacionados à segurança e ao uso inadequado;

Controles de acesso: às diretrizes de controles de acesso buscam estabelecer como as identidades digitais são gerenciadas e como os usuários obtêm acesso a sistemas e informações. Elas abordam autenticação, autorização e princípios de "privilegio mínimo";

Gestão de riscos: as diretrizes de gestão de riscos buscam orientar como identificar, avaliar, gerenciar e mitigar riscos de Segurança da Informação. Elas guiam a tomada de decisões sobre a implementação de medidas de segurança proporcionalmente aos riscos identificados;

Gestão de continuidade: as diretrizes da gestão de continuidade buscam orientar como a organização deve se preparar para manter operações em caso de interrupções, como ataques cibernéticos ou desastres naturais. Elas incluem planos de recuperação de desastres e continuidade de negócios; e

Auditoria e conformidade: às diretrizes de auditoria e conformidade buscam estabelecer como a organização deve monitorar e avaliar a conformidade com suas políticas de segurança da informação. Isso inclui a realização de auditorias regulares para verificar a adesão às diretrizes estabelecidas e às regulamentações relevantes.



SAIBA MAIS

■ [Clique aqui](#) para saber mais sobre a instrução normativa.

As diretrizes fornecem um quadro de referência para a Gestão da Segurança da Informação, possibilitando a realização de tarefas de forma consistente e alinhada com os princípios, objetivos, valores e padrões estabelecidos na organização.

1.5 Competências

Define as atribuições e as responsabilidades dos envolvidos na estrutura de gestão de segurança da informação. As competências devem considerar um conjunto de habilidades técnicas, comportamentais e organizacionais para assegurar a confidencialidade, integridade, disponibilidade e autenticidade. Os administradores de sistemas têm a atribuição de configurar e manter as defesas tecnológicas.

Os analistas de segurança da informação monitoram atividades do ambiente computacional, realizam análises de vulnerabilidades e respondem a incidentes de segurança. Os usuários finais também têm responsabilidades, como seguir as políticas de segurança e participar de treinamentos de conscientização.

1.6 Penalidades

Considerando a IN 01, de 27 de maio de 2020, o inciso VI do artigo 12, estabelece as consequências e as penalidades para os casos de violação da Política de Segurança da Informação ou de quebra de segurança. Elas estão de acordo com as normas já existentes, no ordenamento jurídico vigente, sobre penalidades ao servidor público federal.

As penalidades são estabelecidas para afastar comportamentos inadequados que possam comprometer a confidencialidade, integridade, disponibilidade e autenticidade dos dados. Para tanto, podem ser implementadas ações corretivas e treinamentos adicionais para funcionários que cometem violações inadvertidas, até medidas disciplinares para casos de negligência ou violações intencionais.

1.7 Políticas de atualização

A IN 01, de 27 de maio de 2020, aborda no inciso VII, parágrafos 1º. e 2º. do artigo 12, aborda o período máximo para a revisão da Política de Segurança da Informação e seus normativos.

O § 1º estabelece que a revisão não deve ser superior a quatro anos. Já o § 2º abre a possibilidade da revisão quando necessário para complementar por normas e metodologias, considerando a dinâmica da segurança da informação no contexto da administração pública.

Unidade 2: Gestão de Riscos

Objetivo de aprendizagem

Direcionar e controlar os riscos de privacidade, segurança da informação e cibernética, a fim de adequá-lo aos níveis aceitáveis para o órgão ou entidade.

2.1 Principais definições

A Gestão de Riscos em Segurança da Informação, segundo o Glossário de Segurança da Informação do Gabinete de Segurança Institucional da Presidência da República, está definida como:

“

[...] processo de natureza permanente, estabelecido, direcionado e monitorado pela alta administração, que contempla as atividades de identificação, avaliação e gerenciamento de potenciais eventos que possam afetar a organização, destinado a fornecer segurança razoável quanto à realização de seus objetivos [...]

”

As definições relacionadas aos riscos apresentadas na sequência estão baseadas no Glossário de Segurança da Informação do Gabinete de Segurança Institucional da Presidência da República:

[Risco] no sentido amplo, trata-se da possibilidade de ocorrência de um evento que pode impactar o cumprimento dos objetivos. Pode ser mensurado em termos de impacto e de probabilidade [...]

[Risco de Segurança da Informação] risco potencial associado à exploração de uma ou mais vulnerabilidades de um ou mais ativos de informação, por parte de uma ou mais ameaças, com impacto negativo no negócio da organização [...]

[Identificação de riscos] processo de localizar, listar e caracterizar elementos de risco [...]

[Avaliação de riscos] processo de comparar o risco estimado com critérios de risco predefinidos para determinar a importância do risco [...]

[Mitigação de riscos] processo de ações para reduzir a probabilidade do impacto dos riscos, considerando a implementação de controles de segurança [...]

[Aceitação de riscos] processo para classificar os riscos como aceitáveis, considerando se o custo de mitigação for maior do que o próprio risco [...]

[Transferência dos riscos] forma de tratamento de risco na qual a alta administração decide realizar a atividade, compartilhando com outra entidade o ônus associado a um risco [...]

[Controle dos riscos] medidas implementadas para reduzir a probabilidade de um evento de risco ou seu impacto. Eles podem ser técnicos, operacionais ou administrativos [...]

[Análise dos riscos] uso sistemático de informações para identificar fontes e estimar o risco [...]

[Análise de Custo – Benefício] antes de implementar medidas de mitigação, a organização avalia se os custos associados à mitigação superam os benefícios esperados em termos de redução de risco [...]

[Monitoramento dos Riscos] a gestão de riscos é um processo contínuo de monitoramento, que demanda um método para acompanhar a eficácia das ações de mitigação e identificar mudanças nos riscos ao longo do tempo [...]

[Comunicação de Riscos] processo para compartilhar informações sobre riscos com as partes interessadas internas e externas, garantindo transparência e ação coordenada [...]

[Plano de Resposta a Riscos] plano estruturado que detalha como a organização responderá a eventos adversos caso ocorram. Ele inclui etapas de resposta, atribuições e recursos necessários [...]

[Cultura de Riscos] processo para implementar um conjunto de práticas de sensibilização, conscientização e treinamentos para tornar o ambiente corporativo alinhado com a gestão de riscos [...]

Ao adotar essas definições e aplicar uma abordagem sistemática à gestão de riscos, as organizações podem tomar decisões informadas e proativas para reduzir a exposição a riscos e aumentar sua resiliência diante de ameaças e incertezas.

2.2 Modelo de gestão de riscos institucional

O Modelo de Gestão de Riscos Institucional é um arcabouço estratégico e operacional, com um conjunto de processos e práticas que uma organização implementa para identificar, avaliar, monitorar e mitigar os riscos que podem afetar seus objetivos, metas, operações, reputação e sustentabilidade.

Esse modelo é projetado para ajudar a organização a tomar decisões informadas e proativas em relação aos riscos, a fim de alcançar seus objetivos de forma mais eficaz e eficiente. A gestão de riscos institucional está alicerçada em etapas interligadas e orientadas por princípios de governança sólida e gestão eficiente.

Os princípios chave para a governança sólida são apresentados na figura 10



Princípios-chave para a governança.

Adaptado de DA SILVA MANOEL (2014).

A gestão de riscos institucional é especialmente importante em ambientes complexos e em constante mudança, nos quais as organizações enfrentam diversos tipos de riscos, como tecnológicos, operacionais, estratégicos, legais, de conformidade, financeiros e reputacionais. A implementação de um modelo de gestão de riscos eficaz, como apresentado na figura 11 permite que uma organização:



Art. 11. O processo de gestão de riscos de segurança da informação deve estar alinhado com o modelo de gestão de riscos institucional, compatível com a missão e os objetivos estratégicos do órgão ou entidade, além de considerar, preliminarmente:

I - os processos internos institucionais;

II - os requisitos legais;

III - a política de segurança da informação do órgão ou da entidade;

IV - a política de gestão de riscos institucional, caso exista; e

V - a estrutura do órgão ou da entidade.

Art. 12. O processo de gestão de riscos de segurança da informação deverá fornecer à organização os seguintes documentos:

I - plano de gestão de riscos de segurança da informação;

II - relatório de identificação, análise e avaliação dos riscos de segurança da informação; e

III - relatório de tratamento de riscos de segurança da informação.

Modelo de gestão de riscos

- **Identifique riscos:** permite a identificação de eventos potenciais que podem afetar negativamente os objetos da organização. Esses eventos podem ser ameaças ou oportunidades
- **Avalie riscos:** com os riscos identificados é possível realizar uma avaliação considerando a probabilidade de acontecer o evento de risco e o seu impacto nos objetivos da organização. Com isso, os gestores podem priorizar quais riscos demandam mais atenção
- **Desenvolva estratégias de mitigação:** com base na avaliação dos riscos, a organização desenvolve estratégias de mitigação estejam funcionando e alinhadas com o planejamento realizado para identificar novos riscos
- **Monitore os riscos:** o monitoramento deve ser realizado ao longo do tempo para garantir que as estratégias de mitigação estejam funcionando e alinhadas com o planejamento realizado para identificar novos riscos
- **Fomente a cultura de gestão de riscos:** implementar a cultura de gestão de riscos busca conscientizar os colaboradores sobre a importância da identificação e mitigação de riscos em suas atividades diárias.
- **Seja flexível para as mudanças:** o ambiente de riscos está sempre evoluindo. Sendo assim, o modelo de gestão de riscos deve ser flexível o suficiente para adaptar a novos desafios e oportunidades

Modelo de gestão de riscos.

Fonte: Adaptado de Metodologia de Gestão de Riscos de SIC do SISP (2019)..

Um modelo de gestão de riscos institucional bem desenvolvido permite que uma organização seja mais ágil, resiliente e capaz de tomar decisões informadas em face de incertezas e desafios.

2.3 Documentação: Plano de gestão de riscos, Relatório de identificação, análise e avaliação dos riscos e Relatório de tratamento de risco

Na jornada das organizações em direção ao sucesso e à sustentabilidade, os riscos são companheiros constantes. A incerteza inerente aos negócios e projetos pode impactar os objetivos, a eficiência e a reputação das organizações.

No contexto desafiador do ambiente digital surgem ferramentas essenciais para a tomada de decisões informadas e a minimização dos impactos negativos. Para tanto a Instrução Normativa No. 3 (IN03) do GSI/PR de 28 de maio de 2021, no Art 12, estabelece o processo de gestão de riscos segurança da informação terá que disponibilizar para a organização os documentos:

- I – plano de gestão de riscos de segurança da informação
- II – relatório de identificação, análise e avaliação de riscos de segurança da informação e
- III – relatório de tratamento de riscos de segurança da informação.

Já o Art. 13 da IN03 o Plano de Gestão de Riscos, terá que considerar:

- I – a abrangência da aplicação da gestão de riscos delimitando seu âmbito de atuação e os ativos de informação que serão objeto de tratamento;
- II – a metodologia a ser utilizada deverá contemplar, no mínimo, critérios de avaliação e de aceitação de riscos;
- III – os tipos de riscos;
- IV – o nível de severidade dos riscos;
- V – um modelo de relatório de identificação, análise e avaliação dos riscos de segurança da informação com as orientações para sua elaboração, e
- VI – um modelo do relatório de tratamento de riscos de segurança da informação com as orientações necessárias para sua elaboração.

§ 1º O plano de gestão de riscos da segurança da informação deve ser regularmente revisado a fim de manter atualizados os riscos relativos aos ativos de informação.

§ 2º O processo de implementação do plano de gestão de riscos de segurança da informação deverá considerar dentre outros aspectos as recomendações de mudanças em relação aos critérios de aceitação de riscos a abrangência da atuação do plano, as ações de segurança da informação e as atividades de tratamento de riscos previstas.

O Plano de Gestão de Riscos, o Relatório de Identificação de Riscos e o Relatório de Tratamento de Riscos emergem como elementos estratégicos importantes para a organização gerenciar os riscos. Esses elementos possibilitam uma compreensão holística dos desafios, bem como fornecem uma estrutura para antecipar, enfrentar e gerenciar proativamente as incertezas.

Você pode acessar a IN03 no portal do Gabinete de Segurança Institucional da Presidência da República no ícone Legislação – Instruções Normativas, [clcando aqui](#).

No contexto desafiador do ambiente digital surgem ferramentas essenciais para a tomada de decisões informadas e a minimização dos impactos negativos. Para tanto, o Plano de Gestão de Riscos, o Relatório de Identificação, análise e avaliação dos Riscos e o Relatório de Tratamento de Riscos emergem como elementos estratégicos importantes para a organização gerenciar os riscos. Esses elementos possibilitam uma compreensão holística dos desafios, bem como fornecem uma estrutura para antecipar, enfrentar e gerenciar proativamente as incertezas.

Na sequência apresentamos a documentação:

2.3.1 Plano de Gestão de Riscos

É um documento estratégico que estabelece a abordagem e as diretrizes para gerenciar os riscos. O plano busca identificar, avaliar, responder e monitorar os riscos que podem impactar os objetivos, projetos e operações da organização. Esse plano define as estratégias, as responsabilidades e as atividades a serem seguidas para mitigar os riscos.

O Plano de Gestão de Riscos deve considerar:

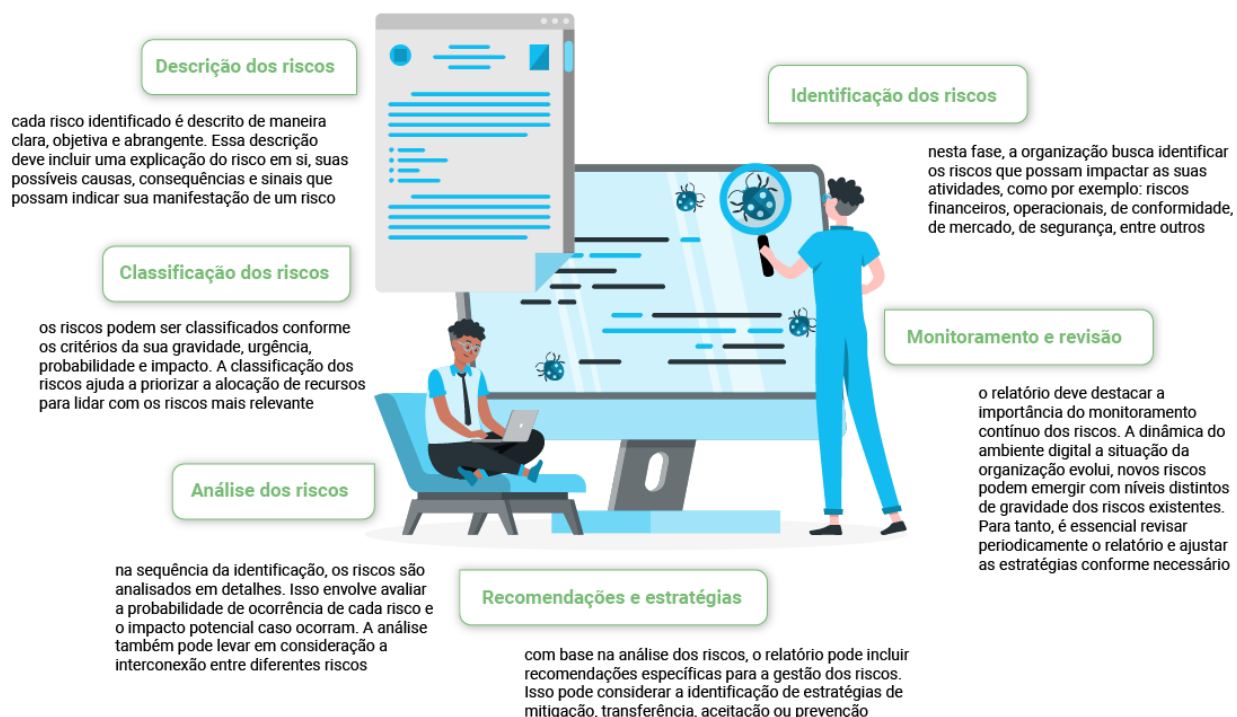


Plano de Gestão de Riscos.

Fonte: Freepik (2024). Elaboração: ENAP (2024).

2.3.2 Relatório de Identificação, análise e avaliação de Riscos

É um documento que lista, descreve e analisa os riscos específicos que foram identificados para a organização. Esse relatório fornece informações para a organização compreender os seus desafios que podem impactar os seus objetivos e, com isso, desenvolver estratégias para realizar a gestão dos riscos identificados.

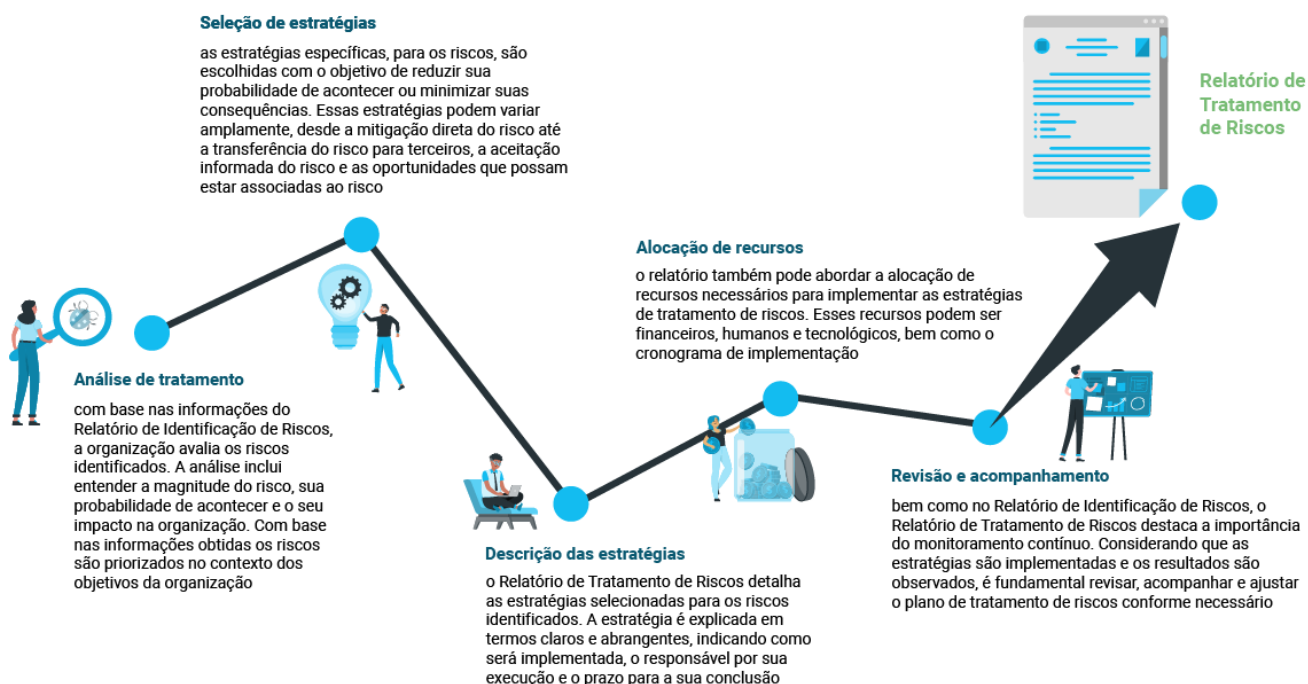


Relatório de Identificação, análise e avaliação de Riscos.

Fonte: Freepik (2024). Elaboração: ENAP (2024).

2.3.3 Relatório de Tratamento de Riscos

É um documento que detalha as estratégias específicas que a organização planeja adotar para abordar cada risco identificado. Esse relatório é projetado para orientar ações concretas que minimizem a probabilidade de acontecer o risco e o seu impacto nos objetivos da organização



Relatório de Tratamento de Riscos.

Fonte: Freepik (2024). Elaboração: ENAP (2024).

Os documentos mencionados, o Plano de Gestão de Riscos, o Relatório de Identificação, análise e avaliação de Riscos e o Relatório de Tratamento de Riscos, são essenciais no processo de gerenciamento de riscos. A integração desses documentos pode assegurar a resiliência e o sucesso da organização diante das incertezas relacionadas com os riscos.

2.4 *Compliance*: Importância no contexto da Segurança da Informação e Segurança Cibernética

A área de *Compliance* desempenha um papel essencial no contexto da Segurança da Informação e Segurança Cibernética, direcionando as organizações para o seu alinhamento com regulamentações, normas, políticas internas e externas, bem como padrões de conduta estabelecidos no tema relacionado com a segurança. A complexidade das ameaças cibernéticas e as crescentes preocupações com a privacidade dos dados tornam a conformidade um elemento fundamental para assegurar a proteção dos dados e informações, bem como a confiança das partes interessadas.

No âmbito da Segurança da Informação, o *compliance* busca assegurar que as práticas e medidas de segurança estejam em conformidade com regulamentações como a GDPR (Regulamento Geral de Proteção de Dados) na União Europeia e a HIPAA (Lei de Portabilidade e Responsabilidade de Seguros de Saúde) nos Estados Unidos, entre outras. No contexto da Segurança Cibernética, o *compliance* desempenha um papel essencial para que as organizações adotem medidas de prevenção, detecção e resposta a incidentes cibernéticos. O cumprimento de regulamentações específicas para a cibersegurança, como a NIST *Cybersecurity Framework* nos EUA, a Lei Geral de Proteção de Dados Pessoais (LGPD) e o Programa de Privacidade e Segurança da Informação (PPSI), no Brasil, ajuda as empresas a mitigar riscos cibernéticos e a estabelecer uma abordagem sistemática para lidar com ameaças no ambiente digital.



IMPORTANTE

O *compliance* no contexto da Segurança da Informação e Segurança Cibernética, ajuda a criar um ambiente de confiança, protegendo dados e informações, mitigando riscos cibernéticos e mantendo a conformidade com a dinâmica das regulamentações.

As ações para assegurar o *compliance* relacionado com as regulamentações da área de segurança fortalece a resiliência das organizações contra ameaças digitais, bem como demonstra o comprometimento da organização com a segurança e privacidade dos dados e informações.

Unidade 3: Gestão de Incidentes

Objetivo de aprendizagem

Gerenciar e controlar os incidentes de segurança para assegurar uma resposta eficaz e organizada a qualquer incidente que ocorra no ambiente computacional da organização, visando minimizar o impacto do incidente, reduzir o tempo de resposta e recuperação, preservar a integridade dos dados e sistemas, e restaurar as operações normais o mais rapidamente possível.

3.1 Principais definições

A gestão de incidentes de Segurança da Informação é um conjunto de práticas e processos destinados a identificar, responder, mitigar e recuperar de maneira eficaz e organizada quando ocorrem incidentes de segurança cibernética ou violações de dados. É uma abordagem estruturada para lidar com eventos adversos que podem comprometer a confidencialidade, integridade, disponibilidade e autenticidade das informações da organização.

Veja os principais conceitos sobre a gestão de incidentes do Glossário de Segurança da Informação do Gabinete de Segurança Institucional da Presidência da República:

Gestão de incidentes de Segurança da Informação: processo que visa integrar atividades de gestão de riscos, gestão de continuidade do negócio, tratamento de incidentes, tratamento da informação, conformidade, credenciamento, segurança cibernética, segurança física, segurança lógica, segurança orgânica e organizacional, aos processos institucionais estratégicos, operacionais e táticos, não se limitando, portanto, à tecnologia da informação [...]

Gestão de incidentes cibernéticos: processo que realiza ações sobre qualquer evento adverso relacionado à Segurança Cibernética dos sistemas ou da infraestrutura de computação [...]

Incidente: interrupção não planejada ou redução da qualidade de um serviço, ou seja, ocorrência, ação ou omissão, que tenha permitido, ou possa vir a permitir, acesso não autorizado, interrupção ou mudança nas operações (inclusive pela tomada de controle), destruição, dano, deleção ou mudança da informação protegida, remoção ou limitação de uso da informação protegida ou ainda a apropriação, disseminação e publicação

indevida de informação protegida de algum ativo de informação crítico ou de alguma atividade crítica por um período de tempo inferior ao tempo objetivo de recuperação [...]

Incidente Cibernético: ocorrência que pode comprometer, real ou potencialmente, a disponibilidade, a integridade, a confidencialidade ou a autenticidade de sistema de informação ou das informações processadas, armazenadas ou transmitidas por esse sistema. Poderá também ser caracterizada pela tentativa de exploração de vulnerabilidade de sistema de informação que caracterize violação de norma, política de segurança, procedimento de segurança ou política de uso. De maneira geral, os tipos de atividade comumente reconhecidas como incidentes cibernéticos são:

- a) tentativas de obter acesso não-autorizado a um sistema ou a dados armazenados;
- b) tentativa de utilização não-autorizada de sistemas para a realização de atividades de processamento ou armazenamento de dados; c) mudanças não-autorizadas de firmware, hardware ou software em um ambiente computacional; d) ataques de negação de serviço (DDoS); e e) demais ações que visem afetar a disponibilidade ou integridade dos dados. Um incidente de segurança cibernética não significa necessariamente que as informações já estão comprometidas; significa apenas que a informação está ameaçada [...]

Incidente de segurança: qualquer evento adverso, confirmado ou sob suspeita, relacionado à segurança dos sistemas de computação ou das redes de computadores [...]

No contexto da gestão de incidentes de Segurança da Informação emergem as ações para:

Identificar os incidentes: ação de reconhecimento e detecção de atividades ou eventos que podem indicar um incidente de segurança, como por exemplo: atividades suspeitas em registros de logs, tentativas de acesso não autorizadas e comportamentos anômalos.

Classificar e priorizar os incidentes: ação de avaliação da gravidade e impacto de um incidente para determinar sua urgência e prioridade de resposta. Com isso, é possível dimensionar os recursos necessários para a gestão do incidente, de maneira eficiente, direcionando as ações de resposta para os incidentes mais críticos.

Responder aos incidentes: ação de implementação de ações coordenadas e planejadas para conter, mitigar e solucionar um incidente. Isso pode incluir isolar sistemas comprometidos, interromper atividades maliciosas e aplicar contramedidas para impedir que o incidente se espalhe.

Recuperar e mitigar os incidentes: ação para restaurar a normalidade na sequência de um incidente, corrigindo as vulnerabilidades apresentadas e restaurando a funcionalidade afetada, bem como a análise das causas raiz para implementar ações que buscam impedir incidentes semelhantes no futuro.

Notificar e comunicar: ação de comunicação adequada dos incidentes para as partes interessadas internas e externas, como autoridades regulatórias, fornecedores, parceiros e clientes. Essa comunicação busca manter a transparência e a confiança na organização.

Documentar: ação para a criação de registros detalhados de todos os aspectos do incidente, incluindo medidas técnicas e administradas realizadas, impacto e lições aprendidas. Esses registros ajudam na análise das informações obtidas na gestão do incidente.

Analisar as lições aprendidas: ação de revisão abrangente do incidente na sequência da sua resolução, focando na identificação das áreas que demandam os processos de resposta a incidentes de forma mais adequados, bem como ajustes nas políticas e controles de segurança para evitar futuros incidentes semelhantes, buscando a melhoria contínua.



SAIBA MAIS

com a sugestão de leitura do Guia de Resposta a Incidentes Cibernéticos, [clcando aqui](#).

A gestão de incidentes de Segurança da Informação é uma abordagem estruturada e interdisciplinar que busca proteger a organização contra ameaças cibernéticas, responder eficazmente a incidentes e melhorar continuamente os processos de segurança. É uma parte essencial da estratégia de Segurança Cibernética para manter a confidencialidade, integridade, disponibilidade e autenticidade dos ativos de informação e a confiança na organização.

3.2 Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos

A Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos (ETIR) é um grupo especializado dentro da organização, responsável por monitorar, identificar, responder e mitigar incidentes de Segurança cibernética. A função principal da ETIR é garantir que a organização esteja pronta para lidar de forma eficaz com a dinâmica das ameaças digitais, minimizando os impactos e reduzindo os riscos de exposição de dados, informações e sistemas críticos. Segundo o Glossário de Segurança da Informação do Gabinete de Segurança Institucional da Presidência da República a Equipe de Tratamento e Resposta a Incidentes Cibernéticos teve o seu termo alterado pelo Decreto nº 10.641, de 2 de março de 2021, para denominação Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos, com a definição, a saber:

“

grupo de agentes públicos com a responsabilidade de prestar serviços relacionados à segurança cibernética para o órgão ou a entidade da administração pública federal, em observância à política de segurança da informação e aos processos de gestão de riscos de segurança da informação do órgão ou da entidade. Anteriormente era chamada de Equipe de Tratamento de Incidentes de Rede [...]

(EQUIPE DE PREVENÇÃO, TRATAMENTO E RESPOSTA A INCIDENTES CIBERNÉTICOS ETIR)

”

Contextualização da ETIR

- **Identifique riscos:** permite a identificação de eventos potenciais que podem afetar negativamente os objetos da organização. Esses eventos podem ser ameaças ou oportunidades
- **Avalie riscos:** com os riscos identificados é possível realizar uma avaliação considerando a probabilidade de acontecer o evento de risco e o seu impacto nos objetivos da organização. Com isso, os gestores podem priorizar quais riscos demandam mais atenção
- **Desenvolva estratégias de mitigação:** com base na avaliação dos riscos, a organização desenvolve estratégias para mitigar ou reduzir a probabilidade e o impacto dos riscos. Para tanto, é necessário implementar controles e planos de contingência
- **Monitore os riscos:** o monitoramento deve ser realizado ao longo do tempo para garanti que as estratégias de mitigação estejam funcionando e alinhadas com o planejamento realizado para identificar novos riscos
- **Implemente uma comunicação transparente:** a comunicação transparente sobre os riscos enfrentados pela organização é fundamental para as partes interessadas terem conhecimento dos eventuais riscos e das medidas de mitigação
- **Fomente a cultura de gestão de riscos:** implementar a cultura de gestão de riscos busca conscientizar os colaboradores sobre a importância da identificação e mitigação de riscos em suas atividades diárias
- **Seja flexível para as mudanças:** o ambiente de riscos está sempre evoluindo. Sendo assim, o modelo de gestão de riscos deve ser flexível o suficiente para se adaptar a novos desafios e oportunidades

Contextualização da ETIR.

Adaptado de Metodologia de Gestão de Riscos de SIC do SISP (2019).

O Centro Integrado de Segurança Cibernética do Governo Digital define a ETIR como:

“

é um grupo de agentes públicos com a responsabilidade de prestar serviços relacionados à segurança cibernética para o órgão ou a entidade da administração pública federal, em observância à política de segurança da informação e aos processos de gestão de riscos de segurança da informação do órgão ou da entidade [...] (ETIR).

”

A Política Nacional de Segurança da Informação, estabelece que as organizações da Administração Pública Federal devem instituir e implementar uma ETIR nos termos da Seção IV – Dos órgãos e das entidades da administração pública federal – Art. 15 – Inciso VII:



Art. 15. Aos órgãos e às entidades da administração pública federal, em seu âmbito de atuação, compete:

VII – instituir e implementar equipe de tratamento e resposta a incidentes em redes computacionais, que comporá a rede de equipes formada pelos órgãos e entidades da administração pública federal, coordenada pelo Centro de Tratamento de Incidentes de Redes do Governo do Gabinete de Segurança Institucional da Presidência da República;

A Instrução Normativa GSI/PR nº 01, de 27 de maio de 2020, com alterações da Instrução Normativa GSI/PR nº 02, de 24 de julho de 2020, dispõe que:



Seção III

Da Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos

Art. 22. Todos os órgãos e entidades que possuem a competência de administrar a infraestrutura de rede de sua organização deverão criar uma Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos.

§ 1º Deverá ser elaborado documento de constituição da Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos, o qual designará suas atribuições e seu escopo de atuação.

§ 2º A Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos será composta, preferencialmente, por servidores públicos civis ocupantes de cargo efetivo ou militares, com capacitação técnica compatível com as atividades dessa equipe.

§ 3º A atuação da Equipe será regida por normativos, padrões e procedimentos técnicos exarados pelo Centro de Tratamento e Resposta de Incidentes Cibernéticos do Governo, sem prejuízo das demais metodologias e padrões conhecidos.

§ 4º As notificações enviadas pela Equipe ao Centro de Tratamento e Resposta à Incidentes Cibernéticos de Governo, bem como a troca de informações entre as Equipes existentes, devem seguir os formatos e os procedimentos que serão estabelecidos pelo Centro de Tratamento e Resposta de Incidentes Cibernéticos do Governo.



SAIBA MAIS

Sugestões de links do Centro Integrado de Segurança Cibernética do Governo Digital: [Implantação de ETIR](#) e [ETIR as a Service](#), onde você também pode ver os serviços disponíveis e fazer solicitações.

CTIR Gov - Centro de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos de Governo [clique aqui](#).

A ETIR integra a estratégia de cibersegurança de uma organização, assegurando que ela esteja preparada para enfrentar e responder de maneira eficaz às ameaças cibernéticas em constante evolução. Sua atuação ajuda a minimizar os riscos e a manter a integridade das operações e dos ativos de informação. Na busca da melhoria contínua para identificar áreas de aprimoramento nos processos de resposta aos incidentes cibernéticos para aprimorar a postura geral de segurança da organização.

3.3 Centro de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos de Governo

Segundo o Site do Centro de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos de Governo, atualizado em 23/03/2023, o [CTIR Gov](#) é integrante do [Departamento de Segurança de Informação e Cibernética – DSIC](#) da [Secretaria de Segurança da Informação e Cibernética – SSIC](#) do [Gabinete de Segurança Institucional – GSI](#) da [Presidência da República - PR](#).

É uma entidade especializada que desempenha suas atividades no contexto governamental e é responsável por coordenar e liderar a resposta a incidentes de Segurança Cibernética que impactam organizações e sistemas do governo. Busca atuar como uma linha de defesa centralizada contra ameaças cibernéticas, trabalhando para detectar, mitigar e responder efetivamente a incidentes que possam comprometer a infraestrutura digital e os ativos de informação do governo.

O acesso se dá, [clikando aqui](#), onde pode-se ver os alertas e as recomendações de segurança.

O CTIR Gov está na categoria “CSIRT de responsabilidade nacional de coordenação” e tem por objetivo coordenar e integrar as ações destinadas à gestão de incidentes computacionais em órgãos ou entidades da Administração Pública Federal – APF. O CTIR Gov é um *Computer Security Incident Response Team* – CSIRT, ou Grupo de Resposta a Incidentes de Segurança, que vem a ser uma organização responsável por receber, analisar e responder a notificações e atividades relacionadas a incidentes de segurança em computadores (BRASIL, CENTRO DE PREVENÇÃO, TRATAMENTO E RESPOSTA A INCIDENTES CIBERNÉTICOS DE GOVERNO, 2023).



Atividades do CTIR Gov.

Fonte: Adaptado de CTIR Gov (2023).



SAIBA MAIS

■ Sobre o CTIR Gov [clique aqui](#).

Ao [clique aqui](#) você terá a gráficos dinâmicos com notificações reportadas pelo CTIR Gov, estatísticas dos incidentes e vulnerabilidades, tipos de incidentes e status das notificações.

3.4 Centro Integrado de Segurança Cibernética do Governo Digital

O Centro Integrado de Segurança Cibernética do Governo Digital – CISC GOV.BR é responsável pela coordenação operacional de ações de prevenção, tratamento e resposta a incidentes cibernéticos de 250 órgãos federais. O CISC GOV.BR é caracterizado como uma Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos - ETIR e atua a nível de coordenação operacional, ofertando uma série de serviços para o seu público-alvo, formado pelos órgãos do Sistema de Administração

dos Recursos de Tecnologia da Informação – SISP. O CISC GOV.BR foi instituído no âmbito do Programa de Privacidade e Segurança da Informação – PPSI, que objetiva elevar o grau de maturidade da proteção de dados pessoais e das ações de segurança da informação nos órgãos e das entidades integrantes do SISP (BRASIL, CENTRO INTEGRADO DE SEGURANÇA CIBERNÉTICA DO GOVERNO DIGITAL, 2023).



SAIBA MAIS

Sobre o Centro Integrado de Segurança Cibernética do Governo Digital e [clique aqui](#).

O CISC Gov.br apoia 250 órgãos federais na coordenação operacional de ações de prevenção, tratamento e resposta a incidentes cibernéticos.

Unidade 4: Principais conceitos de sensibilização, conscientização e capacitação

Objetivo de aprendizagem

Fomentar e disseminar a importância de ações de capacitação e de profissionalização de recursos humanos em temas relacionados à segurança da informação para a consolidação da mudança cultural.

4.1 Ações de sensibilização, conscientização e capacitação

As ações de sensibilização, conscientização e capacitação são essenciais no contexto da Segurança da Informação e Segurança Cibernética, com foco na em ações que buscam criar uma cultura de segurança na organização. Essas ações estabelecem uma trilha de treinamento para os usuários nas questões relacionadas com melhores práticas de segurança no ambiente digital. Com isso, os colaboradores da organização passam a conhecer suas responsabilidades para a proteção dos ativos de informação contra os incidentes cibernéticos.



IMPORTANTE

Ações de sensibilização: a sensibilização busca destacar a importância da Segurança Cibernética e das ameaças associadas, por meio de campanhas de sensibilização, mensagens visuais e estudo de caso de incidentes.

Ações de conscientização: a conscientização busca informar os usuários sobre as práticas de segurança específicas que devem ser seguidas no ambiente digital. As ações de conscientização frequentemente envolvem treinamentos, workshops e materiais educativos.

Ações de capacitação: a capacitação busca fornecer habilidades práticas para administrar as situações relacionadas com a Segurança Cibernética. As ações de capacitação podem incluir treinamento para reconhecer e relatar ameaças, utilizar de forma segura as tecnologias e compreender as políticas de segurança da organização.

Exemplos das ações:

Seminários e workshops: realizar palestras, seminários e workshops para os colaboradores sobre temas de Segurança Cibernética, considerando ameaças comuns, boas práticas e medidas de prevenção.

Simulações de phishing: enviar e-mails simulados de phishing para os colaboradores, tendo como objetivo avaliar a sua capacidade de identificar e-mails maliciosos, fornecendo feedback e treinamento adicional com base nos resultados.

Treinamento para implementar senhas fortes: oferecer orientações sobre como criar senhas fortes e únicas, bem como introduzir práticas de gerenciamento de senhas.

Treinamento de engenharia social: simular situações de engenharia social para ensinar os colaboradores a reconhecer tentativas de manipulação e fraude por parte de atacantes.

Exercícios de resposta a incidentes: realizar simulações de incidentes de Segurança Cibernética para treinar a equipe de segurança e os colaboradores sobre como responder aos ataques e mitigar eventuais impactos na organização.

Uso seguro de dispositivos móveis: fornecer orientações sobre como usar dispositivos móveis (smartphones e tablets) de maneira segura, incluindo o uso de redes Wi-Fi públicas e aplicativos confiáveis.

Treinamento de reconhecimento de malware: ensinar os colaboradores a reconhecer sinais de infecção por malware e como agir caso suspeitem de um dispositivo comprometido.

Treinamento para teletrabalho seguro: oferecer orientações sobre como trabalhar remotamente de forma segura, incluindo as boas práticas para uso de conexão remota e compartilhamento seguro de dados e informações.

Testes de segurança em aplicativos: realizar treinamentos sobre a importância de testes de segurança em aplicativos e sistemas antes de serem implementados, para evitar vulnerabilidades.

Treinamento de segurança para desenvolvedores: educar os desenvolvedores sobre práticas seguras de codificação, para eliminar vulnerabilidades e falhas de segurança em software.

Campanhas de conscientização em redes sociais: realizar campanhas de conscientização para uso seguro das redes sociais da organização.

Testes de invasão controlados: realizar testes de invasão controlados em sistemas da organização para identificar vulnerabilidades e, com isso, usar os resultados como exemplos de lições aprendidas.

Treinamento regular: manter um programa contínuo de treinamento e conscientização em Segurança Cibernética para permitir que todos os colaboradores fiquem atualizados e preparados para lidar com a dinâmica das ameaças cibernéticas.

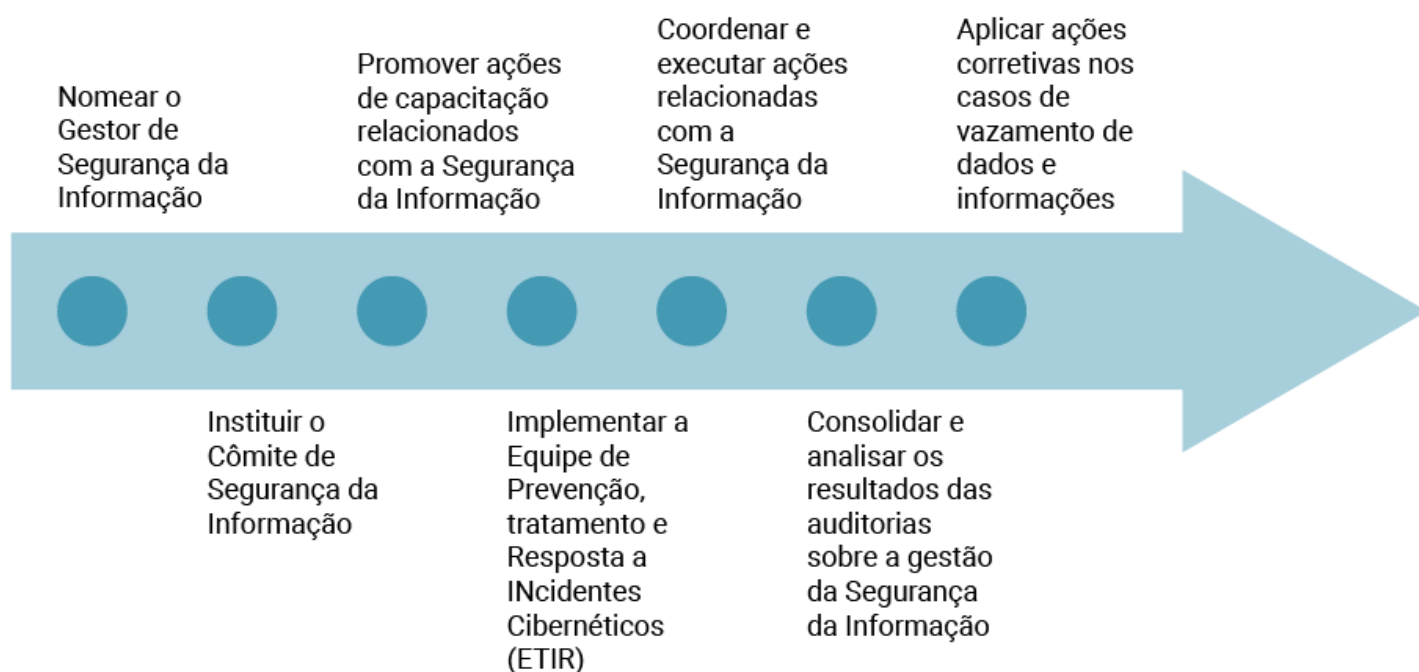
As ações de sensibilização, conscientização e capacitação permitem instrumentalizar os colaboradores no contexto da Segurança Cibernética. São ações que fomentam a cultura de segurança com comportamentos alinhados às boas práticas de segurança.

4.2 Instrução Normativa nº 1, de 27 de maio de 2020

A Instrução Normativa no 1, de 27 de maio de 2020, dispõe sobre a Estrutura de Gestão da Segurança da Informação nos órgãos e nas entidades da Administração Pública Federal.

No seu Art. 2º a Estrutura de Gestão da Segurança da Informação nos órgãos e nas entidades da administração pública federal dispõe sobre as orientações para gestão de segurança da informação que deverão ser observadas e implementadas pelos órgãos e pelas entidades da administração pública federal, direta e indireta, com a finalidade de assegurar a disponibilidade, a integridade, a confidencialidade e a autenticidade da informação em âmbito nacional (BRASIL, INSTRUÇÃO NORMATIVA No 1, GABINETE DE SEGURANÇA INSTITUCIONAL, 2023).

Segundo a IN 01 a Estrutura de Gestão da Segurança da Informação nos órgãos e nas entidades da Administração Pública Federal, deve seguir o fluxo conforme apresentado na figura 14.



Fluxo da Estrutura de Gestão da Segurança da Informação.

Fonte: GSI (2023).

- Nomear o Gestor de Segurança da Informação
- Instruir o Comitê de Segurança da Informação
- Promover ações de capacitação relacionados a a Segurança da Informação
- Implementar a Equipe de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos (ETIR)
- Coordenar e executar ações relacionadas com a Segurança da Informação
- Consolidar e analisar os resultados das auditorias sobre a gestão da Segurança da Informação
- Aplicar ações corretivas, nos casos de vazamento de dados e informações



SAIBA MAIS

■ Leia sobre essa instrução e seu fluxo, [clcando aqui](#).

A Estrutura de Gestão da Segurança da Informação deve estar presente no contexto organizacional dos órgãos e nas entidades da administração pública federal para assegurar a disponibilidade, a integridade, a confidencialidade e a autenticidade da informação nas organizações.

4.3 Controle 14 – Conscientização sobre segurança e treinamento de competências

Para um programa de Conscientização pode ser utilizado o Controle 14 para estabelecer e manter um programa de conscientização de segurança para influenciar o comportamento da força de trabalho para ser consciente em segurança e devidamente qualificada para reduzir os riscos de segurança cibernética para a empresa (CENTER FOR INTERNET SECURITY, 2023). A figura 15 apresenta as práticas do Controle 14.



Práticas do Controle 14.

Fonte: CIS (2024).



SAIBA MAIS

■ Sobre o Controle 14 [clique aqui](#).

Assim, percebe-se que o programa de conscientização de segurança fortalece o comportamento de segurança cibernética na organização e qualifica a força de trabalho.

Referências

BEAL, A. **Segurança da Informação**: princípios e melhores práticas para a proteção dos ativos de informação nas organizações. Atlas, 2005.

BRASIL. **Centro Integrado de Segurança Cibernética do Governo Digital**. 2023. Disponível em: <https://www.gov.br/cisc/pt-br/etir-as-a-service/implantacao-de-etir>. Acesso em: 23 de agosto de 2023.

BRASIL. **Centro de Prevenção, Tratamento e Resposta a Incidentes Cibernéticos de Governo**. 2023. Disponível em: <https://www.gov.br/ctir/pt-br>. Acesso em: 23 de agosto de 2023.

BRASIL. **Gabinete de Segurança Institucional**. Glossário de Segurança da Informação. 2023. Disponível em: <https://www.gov.br/gsi/pt-br/assuntos/dsi/glossario-de-seguranca-da-informacao-1>. Acesso em: 20 de agosto de 2023.

BRASIL. **Instrução Normativa no 1**. Gabinete de Segurança Institucional. Glossário de Segurança da Informação. 2023. Disponível em: https://www.gov.br/gsi/pt-br/composicao/SSIC/dsic/legislacao/copy_of_IN01_consolidada.pdf. Acesso em: 21 de agosto de 2023.

CENTER FOR INTERNET SECURITY, **CIS Controls**, Disponível em: <https://www.cisecurity.org/>. Acesso em: 15 de agosto de 2023.

DA SILVA MANOEL, Sergio. **Governança de segurança da informação**: como criar oportunidades para o seu negócio. Brasport, 2014.

4 Frameworks de Segurança

Bem-vindo(a) ao Módulo 4

O objetivo deste módulo é apresentar os principais *frameworks* no contexto da Segurança da Informação e Segurança Cibernética.

Ao completar este módulo, você terá conhecimento sobre os *frameworks* relacionados com a Segurança da Informação e Segurança Cibernética para estabelecer e manter a proteção adequada dos ativos de informação da organização. Esses frameworks são conjuntos de diretrizes, melhores práticas e padrões que ajudam a definir e implementar medidas de segurança de forma estruturada e eficaz.

Unidade 1: Frameworks

Objetivo de aprendizagem

Conhecer os *frameworks* de segurança.

1.1 Importância

No cenário atual, a crescente digitalização de informações e processos organizacionais têm proporcionado inúmeros benefícios, no entanto, tem gerado uma crescente necessidade de aumento da privacidade e proteção dos dados, informações e sistemas contra as ameaças cibernéticas. Essa proteção tem sido uma prioridade para organizações de todos os setores. Nesse contexto, os *frameworks* de Segurança da Informação e Segurança Cibernética emergem como ferramentas essenciais para abordar as complexidades das ameaças cibernéticas e estabelecer estratégias eficazes de defesa do ambiente digital.

Os *frameworks* desempenham um papel essencial para assegurar a privacidade e proteção dos dados de informações e sistemas em um ecossistema digital, dinâmico e complexo. Essas são características inerentes a ecossistemas digitais interconectados, fato que propicia o aumento dos ataques cibernéticos. Nesse contexto, os *frameworks* têm um papel de destaque para a:

Estruturação e organização: os *frameworks* buscam estruturar de forma organizada e lógica as questões de segurança, estabelecendo diretrizes e padrões claros para ajudar as organizações a criar planos estratégicos e operacionais de segurança, implementar políticas, procedimentos eficazes e organizar recursos de tecnologia de maneira eficiente;

Padronização de práticas: os *frameworks* buscam promover a padronização das práticas de segurança, para assegurar que todas as áreas críticas sejam abordadas de maneira robusta e consistente. A padronização é essencial para evitar lacunas na segurança e assegurar que todos os aspectos relevantes sejam considerados;

Identificação e mitigação de riscos: os *frameworks* ajudam identificar de forma proativa as vulnerabilidades e ameaças, permitindo que as organizações avaliem os riscos e tomem medidas de mitigação;

Conformidade regulatória: os *frameworks* buscam fornecer orientações específicas para cumprir regulamentações relacionadas com a Segurança Cibernética, para assegurar que a organização esteja em conformidade e evite penalidades legais;

Resposta a incidentes: os *frameworks* buscam estabelecer diretrizes para a gestão dos incidentes de Segurança Cibernética, com ações de resposta, recuperação e comunicação relacionada com os incidentes de segurança. Ter um plano de resposta a incidentes estruturado é essencial para minimizar danos em caso de violações de segurança;

Melhoria contínua: os *frameworks* buscam incentivar a melhoria contínua das práticas de segurança. Eles permitem que as organizações avaliem periodicamente sua postura de segurança, identifiquem áreas de vulnerabilidades e ajustem suas estratégias de segurança para se adaptar a novas ameaças e desafios;

Conscientização e treinamento: a implementação de um *framework* possibilita estruturar um programa de sensibilização, conscientização e treinamento dos colaboradores, tornando todos os membros da organização conscientes da importância da Segurança Cibernética e das suas responsabilidades para a proteção dos ativos de informação;

Credibilidade e confiança: o uso dos *frameworks* reconhecidos e a aplicação de melhores práticas de segurança por eles estruturadas aumentam a credibilidade da organização na visão das partes interessadas; e

Preparação para ameaças emergentes: os *frameworks* passam por atualizações para abordar ameaças cibernéticas emergentes. Com isso, as atualizações permitem que as organizações estejam preparadas para enfrentar desafios futuros à Segurança Cibernética.

1.2 Como funcionam

Os *frameworks* funcionam como um conjunto de diretrizes e melhores práticas para garantir a confidencialidade, integridade, disponibilidade e autenticidade dos dados, informações e sistemas da organização. Na sequência estão apresentados os passos estruturados que descrevem o funcionamento dos *frameworks*:

Passo 1: Avaliação de riscos

Identifica os ativos de informações e sistemas que são essenciais para as operações da organização;

Analisa as ameaças cibernéticas que podem impactar esses ativos, considerando ameaças internas e externas;

Avalia e identifica as vulnerabilidades nos sistemas e processos que podem ser utilizadas pelas ameaças; e

Prioriza e classifica os riscos com base em sua probabilidade e impacto.

Passo 2: Desenvolvimento de políticas e procedimentos

Elabora políticas de segurança para estabelecer as diretrizes gerais para proteger os ativos e mitigar os riscos identificados; e

Documenta e desenvolve os procedimentos operacionais de forma padronizada para detalhar como as políticas serão implementadas na prática.

Passo 3: Implementação de Controles de Segurança

Seleciona os controles de segurança apropriados, como firewalls, sistemas de detecção de intrusões, criptografia, autenticação multifator etc.; e

Implementa, configura e aplica os controles de segurança selecionados em toda a organização.

Passo 4: Treinamento e Conscientização

Realiza treinamento em Segurança Cibernética para todos os colaboradores, para que compreendam as políticas e saibam como utilizar os recursos tecnológicos de forma adequada e segura; e

Promove a conscientização sobre ameaças cibernéticas e a importância da segurança da informação, implementando campanhas de conscientização.

Passo 5: Monitoramento e Detecção

Estabelece monitoramento contínuo para acompanhar a atividade do ambiente digital e do sistema em busca de comportamentos suspeitos;

Configura alertas que notifiquem a equipe de segurança sobre atividades anômalas; e

Registra eventos (logs) para análise e estudo das causas, com isso, estabelecer ações corretivas.

Passo 6: Resposta a Incidentes

Desenvolve um plano de resposta a incidentes que detalha os passos a serem seguidos quando uma violação de segurança for detectada;

Testa o plano de simulação de incidentes para assegurar que a equipe saiba como responder eficazmente; e

Implementa medidas para conter a violação, restaurar a normalidade e aprender com o incidente para evitar recorrências.

Passo 7: Melhoria Contínua

Avalia regularmente a eficácia das políticas, procedimentos e controles de segurança;

Atualiza as medidas de segurança com base nas lições aprendidas e nas mudanças no cenário de ameaças; e

Acompanha as tendências atento às novas ameaças cibernéticas e às atualizações regulatórias para manter a segurança atualizada.

Passo 8: Conformidade Regulatória

Assegura de que as políticas e controles estejam em conformidade com as regulamentações relevantes; e

Mantém registros detalhados para passar por auditorias regulatórias.

Os passos estruturados formam a base para a implementação bem-sucedida de um framework de Segurança Cibernética, assegurando que a organização esteja preparada para proteger seus ativos de informações e sistemas contra ameaças cibernéticas.

1.3 Como utilizar

A portaria SGD/MGI No. 852, no seu artigo 8º., estabelece que os órgãos e as entidades deverão implementar o Framework de Privacidade e Segurança da Informação, sendo de responsabilidade da Estrutura de Governança de cada órgão e entidade. Considera-se como etapas para a implementação do framework pelos órgãos e entidades pertencentes ao SISP:

Etapas para implementação do framework

I - autoavaliação: execução de avaliação pelo próprio órgão, considerando o modelo de avaliação de maturidade e capacidade disponibilizado por meio do framework;

II - análise de lacunas: a partir da autoavaliação, esta etapa consiste na identificação de oportunidades quanto à necessidade de implementação de medidas ou de melhoria contínua das medidas já implementadas para aumento da capacidade e maturidade do órgão ou entidade;

III - planejamento: após identificadas as oportunidades de melhorias identificadas na etapa anterior, o órgão deve realizar planejamento que especifique o prazo e as necessidades de recursos para implementação, considerando aspectos orçamentários e de recursos humanos do próprio órgão ou entidade; e

IV - implementação: esta etapa consiste na implementação das medidas ou na melhoria contínua de medidas já implementadas para aumento da capacidade e maturidade do órgão.

O órgão ou entidade deverá observar os controles considerados como prioritários pela Secretaria de Governo Digital, em comunicação periódica realizada por meio de ato administrativo para a Estrutura de Governança.

1.4 Frameworks disponíveis

ISO 27001/27002: a [ISO 27001](#) é uma norma internacional para sistemas de gestão de Segurança da Informação. Ela fornece um conjunto de requisitos para estabelecer, implementar, manter e melhorar um sistema de gestão de segurança da informação. A [ISO 27002](#), estabelece diretrizes detalhadas para a implementação dos controles de Segurança da Informação.

NIST Cybersecurity Framework: desenvolvido pelo Instituto Nacional de Padrões e Tecnologia (NIST) dos EUA, esse framework apresenta diretrizes para ajudar as organizações a melhorar sua postura de Segurança Cibernética. Ele é composto por funções para identificar, proteger, detectar, responder e recuperar.

CIS Controls: é um conjunto de melhores práticas destinadas a reduzir o risco de ameaças cibernéticas. Eles fornecem orientações detalhadas sobre a implementação de controles de segurança eficazes.

COBIT (Control Objectives for Information and Related Technologies): é um *framework* desenvolvido pelo ISACA que se concentra na governança de tecnologia da informação. Ele ajuda as organizações a estabelecer um ambiente de controle sólido, garantindo que a área de tecnologia da informação esteja alinhada com os objetivos da organização e em conformidade com as regulamentações relacionadas com a Segurança Cibernética.

MITRE ATT&CK: é um modelo de matriz de táticas e técnicas de ataque cibernético. Fornece uma estrutura que permite entender as táticas e técnicas que os adversários cibernéticos podem utilizar, e ajuda na melhoria para a detecção e a resposta a ameaças.

FISMA (Federal Information Security Management Act): é uma legislação dos EUA que exige que as agências federais desenvolvam, implementem e mantenham programas de Segurança da Informação, bem como diretrizes robustas para a Segurança Cibernética no setor público.

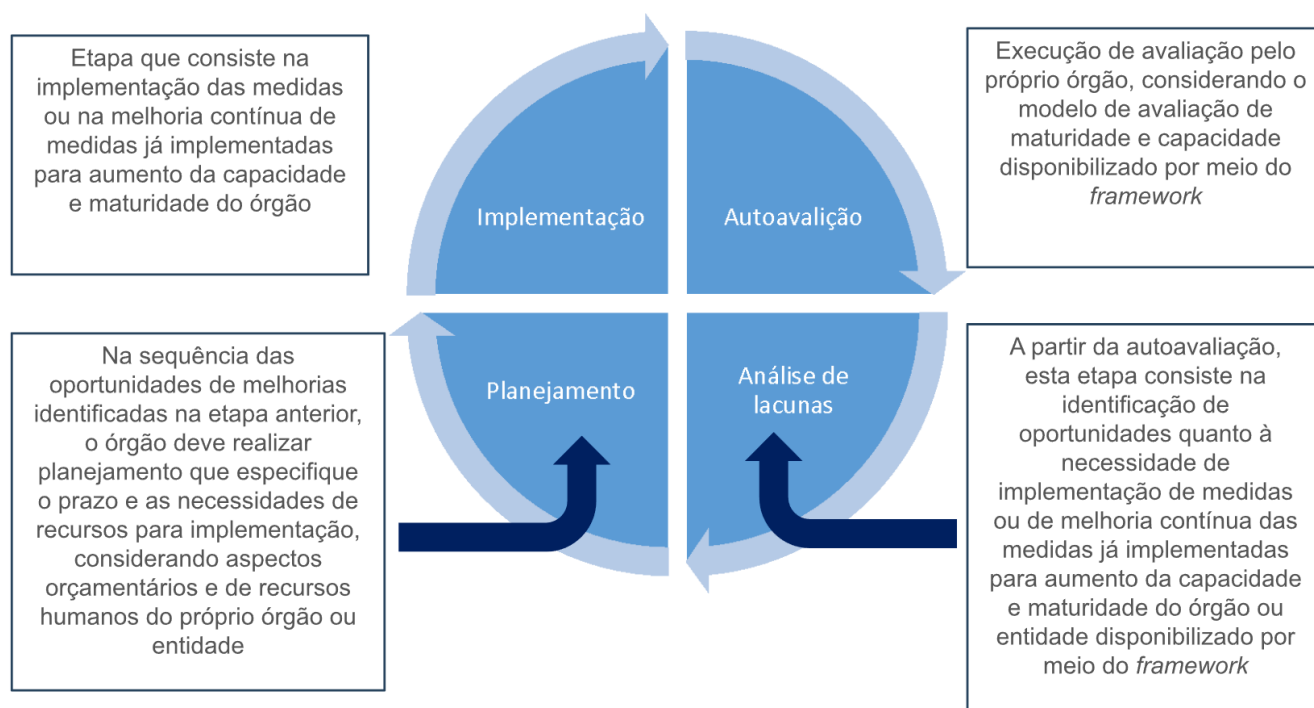
NIST SP 800-53: é um conjunto de controles de segurança desenvolvido pelo NIST dos EUA para uso em agências federais. É referenciado e adotado por organizações públicas e privadas para estabelecer medidas de segurança abrangentes.

ITIL (Information Technology Infrastructure Library): o ITIL é mais conhecido por seus processos de gerenciamento de serviços de tecnologia da informação. No entanto, o ITIL apresenta práticas relacionadas à Segurança Cibernética. Ajuda as organizações a integrar a Segurança Cibernética em suas operações de tecnologia da informação.

NICE Framework (National Initiative for Cybersecurity Education): desenvolvido pelo governo dos EUA. Esse framework define funções e especializações em Segurança Cibernética e fornece orientações para o desenvolvimento de força de trabalho em Segurança Cibernética.

1.5 Framework de Privacidade e Segurança da Informação (SGD/MGI)

O Programa de Privacidade e Segurança da Informação (PPSI) caracteriza-se como um conjunto de projetos e processos de adequação nas áreas de privacidade e Segurança da Informação e tem como valores: a maturidade; a resiliência; a efetividade; a colaboração e a inteligência. No âmbito da Secretaria de Governo Digital, a Diretoria de Privacidade e Segurança da Informação é a unidade responsável pelo PPSI (BRASIL, PROGRAMA DE PRIVACIDADE E SEGURANÇA DA INFORMAÇÃO, SECRETARIA DE GOVERNO DIGITAL, 2023). A figura 16 apresenta as etapas para implementação do *framework* PPSI.



Etapas para implementação do *framework* PPSI.

Fonte: Governo Digital (2023).

Saiba mais sobre os diversos documentos dos *frameworks* disponíveis e seus links no quadro 5 a seguir

Frameworks	Links
O que é o Framework de Privacidade e Segurança da Informação e quais são suas etapas de implementação	https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/framework
Manual do Usuário da Ferramenta do Framework de Privacidade e Segurança da Informação	https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/ppsi/manual_ferramenta_framework.pdf
Para auxiliar no fomento à maturidade e à resiliência dos órgãos e entidades, em termos de Privacidade e Segurança da Informação, são disponibilizadas nesta página as principais ações empreendidas por meio do Programa de Privacidade e Segurança da Informação, Framework, Centro Integrado de Segurança Cibernética, Ações de Capacitação e os Guias e Modelos	https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/ppsi/manual_ferramenta_framework.pdf
PROGRAMA DE PRIVACIDADE E SEGURANÇA DA INFORMAÇÃO - PPSI	https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/ppsi/
Governo Digital	https://www.gov.br/governodigital/pt-br

Documentos do Frameworks e links.

Fonte: do autor (2023).

Os *frameworks* de Segurança da Informação e Segurança Cibernética desempenham um papel essencial na proteção e na gestão eficaz dos riscos associados ao mundo digital. Eles oferecem orientação, estrutura e direção necessárias para enfrentar a dinâmica das ameaças cibernéticas para assegurar a confidencialidade, integridade, disponibilidade e autenticidade dos ativos de informação da organização.

1.5.1 Estruturação básica de gestão em privacidade e segurança da informação (Controle 0) - Anexo III

O Anexo III relaciona uma lista de medidas do controle de estruturação básica em privacidade e segurança da informação. Esse controle busca realizar às ações específicas de conformidade básica estabelecidas na IN SGD/ME nº 94, de 23 de dezembro de 2022, IN CGU nº 3, de 9 de junho de 2017, IN GSI/PR nº 1, de 27 de maio de 2020 e LGPD - Lei nº 13.709, de 14 de agosto de 2018.

Id	Função NIST	Medida	Descrição da medida	Referências
1		O órgão nomeou um Gestor de Tecnologia da Informação e Comunicação?	O Gestor de Tecnologia da Informação e Comunicação, dentre outras atribuições, nos termos da Portaria nº 778, de 4 de abril de 2019, responsável por planejar, implementar e melhorar continuamente os controles de privacidade e segurança da informação em soluções de tecnologia da informação e comunicações, considerando a cadeia de suprimentos relacionada à solução.	Portaria nº 778, de 4 de abril de 2019
2		O órgão nomeou um Gestor de Segurança da Informação?	O Gestor de Segurança da Informação, dentre outras atribuições, nos termos da Instrução Normativa nº 1, de 27 de maio de 2020, do Gabinete de Segurança Institucional, da Presidência da República - GSI/PR, responsável por planejar, implementar e melhorar continuamente os controles de segurança da informação em ativos de informação.	Art. 15, inciso I da Instrução Normativa GSI nº 1, de 27 de maio de 2020
3		O órgão nomeou um Responsável pela Unidade de Controle Interno?	O Responsável pela Unidade de Controle Interno, atuará no apoio, supervisão e monitoramento das atividades desenvolvidas pela primeira linha de defesa prevista pela Instrução Normativa CGU nº 3, de 9 de junho de 2017.	Instrução Normativa CGU nº 3, de 9 de junho de 2017
4		O órgão instituiu um Comitê de Segurança da Informação?	Instituir um Comitê de Segurança da Informação ou estrutura equivalente, para deliberar sobre os assuntos relativos à Política Nacional de Segurança da Informação.	Art. 15, inciso II da Instrução Normativa GSI nº 1, de 27 de maio de 2020

5		O órgão instituiu uma Equipe de Tratamento e Resposta a Incidentes Cibernéticos - ETIR?	nstituir e implementar Equipe de Tratamento e Resposta a Incidentes Cibernéticos - ETIR, que constituirá a rede de equipes, integrada pelos órgãos e pelas entidades da administração pública federal, coordenada pelo Centro de Tratamento e Resposta a Incidentes Cibernéticos de Governo do Gabinete de Segurança Institucional da Presidência da República.	Art. 15, inciso IV da Instrução Normativa GSI nº 1, de 27 de maio de 2020
6		O órgão elaborou uma Política de Segurança da Informação - POSIN?	É obrigatório a todos os órgãos e as entidades da administração pública federal possuir uma Política de Segurança da Informação - POSIN, implementada a partir da formalização e aprovação por parte da autoridade máxima da instituição, com o objetivo de estabelecer diretrizes, responsabilidades, competências e subsídios para a gestão da segurança da informação	Art. 9º da Instrução Normativa GSI nº 1, de 27 de maio de 2020
7	GOVERNAR-P (*)	O órgão nomeou um Encarregado pelo Tratamento de Dados Pessoais?	O Encarregado pelo Tratamento de Dados Pessoais, dentre outras atribuições, nos termos do art. 41, §2º, da Lei nº 13.709, de 14 de agosto de 2018 (Lei Geral de Proteção de Dados - LGPD), responsável por conduzir o diagnóstico de privacidade, bem como orientar, no que couber, os gestores proprietários dos ativos de informação, responsáveis pelo planejamento, implementação e melhoria contínua dos controles de privacidade em ativos de informação que realizem o tratamento de dados pessoais ou dados pessoais sensíveis	Art. 5º, inciso VIII e Art. 41 da Lei Geral de Proteção de Dados Pessoais nº 13.709, de 14 de agosto de 2018

Quadro 6 - ANEXO III - Tabela de controle e medidas de estruturação básica em privacidade e segurança da informação.

Fonte: Governo Digital (2023).



SAIBA MAIS

(*) Governar-P: desenvolve e implementa a estrutura de governança organizacional para permitir uma compreensão contínua das prioridades de gestão de riscos da organização que são transmitidas pelo risco de privacidade.

1.5.2 Segurança Cibernética (1 a 18)

Considerando as melhores práticas para estruturar a Segurança Cibernética das organizações os CIS Controls, abreviação de "Center for Internet Security Controls," apresenta um conjunto de melhores práticas desenvolvidas pela organização sem fins lucrativos Center for Internet Security (CIS). O Guia CIS Controle v8 é composto de 18 controles que abordam temas da Segurança Cibernética.

Esses controles são:

Controle 1: Inventário e Controle de Ativos Institucionais;

Controle 2: Inventário e Controle de Ativos de Software;

Controle 3: Proteção de Dados;

Controle 4: Configuração Segura de Ativos Institucionais e Software;

Controle 5: Gestão de Contas;

Controle 6: Gestão de Controle de Acesso;

Controle 7: Gestão Contínua de Vulnerabilidades;

Controle 8: Gestão de Registros de Auditoria;

Controle 9: Proteções de E-mail e Navegador Web;

Controle 10: Defesas Contra Malware;

Controle 11: Recuperação de Dados;

Controle 12: Gestão da Infraestrutura de Rede;

Controle 13: Monitoramento e Defesa da Rede;

Controle 14: Conscientização e Treinamento de Competências sobre Segurança;

Controle 15: Gestão de Provedor de Serviços;

Controle 16: Segurança de Aplicações;

Controle 17: Gestão de Resposta a Incidentes; e

Controle 18: Testes de Invasão.

1.5.3 Controles de Privacidade (19 a 31)

O Guia do *Framework* de Privacidade e Segurança da Informação elaborado pela Secretaria de Governo Digital do Ministério da Gestão e Inovação em Serviços Públicos, no seu Capítulo 4 aborda os 13 controles de privacidade.

Controles de privacidade:

Controle 19: Inventário e Mapeamento;

Controle 20: Finalidade e Hipóteses Legais;

Controle 21: Governança;

Controle 22: Políticas, Processos e Procedimentos;

Controle 23: Conscientização e Treinamento;

Controle 24: Minimização de Dados;

Controle 25: Gestão do Tratamento;

Controle 26: Acesso e Qualidade;

Controle 27: Compartilhamento, Transferência e Divulgação;

Controle 28: Supervisão em Terceiros;

Controle 29: Abertura, Transparência e Notificação;

Controle 30: Avaliação de Impacto, Monitoramento e Auditoria; e

Controle 31: Segurança Aplicada à Privacidade.

Essas melhores práticas buscam estruturar a Segurança Cibernética das organizações, com isso, possibilitando implementar as ações para proteger os dados, informações e contra ameaças cibernéticas. Os CIS Controls apresentam orientações claras e objetivas para organizações de todos os tamanhos e setores, com foco na postura de Segurança Cibernética.

Referências

BRASIL. **Programa de Privacidade e Segurança da Informação**. Secretaria de Governo Digital. 2023. Disponível em: <https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/ppsi-atual>. Acesso em: 23 de agosto de 2023.

5 Visão Geral do CIS Controls

Bem-vindo(a) ao Módulo 5

O objetivo deste módulo é apresentar uma visão geral dos CIS Controls no contexto da Segurança Cibernética.

Ao completar este módulo, você terá uma visão geral dos CIS Controls e sua utilidade como ação defensiva no contexto da Segurança Cibernética para estabelecer e manter a proteção adequada dos ativos de informação da organização. Esses controles estão estruturados para ajudar nas respostas às crescentes ameaças cibernéticas no ambiente digital.

Unidade 1: Visão geral

Objetivo de aprendizagem

Conhecer os CIS Controls.

1.1 Sobre o CIS Controls

No cenário atual, a crescente digitalização de informações e processos organizacionais têm proporcionado inúmeros benefícios, no entanto, tem gerado uma crescente necessidade de aumento da privacidade e proteção dos dados, informações e sistemas contra as ameaças cibernéticas. Essa proteção tem sido uma prioridade para organizações de todos os setores. Nesse contexto, os *frameworks* de Segurança da Informação e Segurança Cibernética emergem como ferramentas essenciais para abordar as complexidades das ameaças cibernéticas e estabelecer estratégias eficazes de defesa do ambiente digital.

1.2 Como começar

Na sequência estão apresentados os passos para implementar os CIS Controls:

Passo 1 – Programa de Conscientização

Implemente um programa de conscientização para fornecer aos colaboradores uma compreensão sólida sobre a importância da segurança cibernética e os riscos associados.

Passo 2 – Avaliação de Riscos

Realize uma avaliação de riscos para identificar os ativos críticos, ameaças potenciais e vulnerabilidades em seu ambiente organizacional.

Passo 3 – Seleção de Controles

Escolha os controles a serem implementados tendo como base a avaliação de riscos. Escolha os controles dos CIS que são mais relevantes para a sua organização. Para tanto, a participação dos colaboradores inseridos no programa de conscientização é essencial. Esses colaboradores têm o entendimento do negócio, tornando o seu conhecimento um instrumento útil para o alinhamento dos controles com os objetivos da organização.

Passo 4 – Implementação Gradual

Implemente os controles escolhidos de forma gradual, priorizando aqueles que têm maior impacto na mitigação de riscos. Lembrando da importância dos colaboradores para o processo de priorização dos controles.

Passo 5 – Monitoramento e Melhoria Contínua

Estruture um processo contínuo de monitoramento, avaliação e melhoria dos controles de acordo com a dinâmica das ameaças no contexto do ambiente digital.

1.3 Estrutura

***Basic CIS Controls* (Controles Básicos dos CIS)**

são controles de segurança essenciais que todas as organizações devem implementar uma base sólida de segurança;

***Foundational CIS Controls* (Controles Fundamentais dos CIS)**

são controles que buscam aprimorar a postura da Segurança Cibernética na organização, transcendendo os controles básicos e protegendo contra ameaças mais sofisticadas; e

***Organizational CIS Controls* (Controles Organizacionais dos CIS):**

são controles com foco na gestão e governança da Segurança Cibernética em nível organizacional.

1.4 Guias do CSI

O CIS fornece uma série de guias e recursos para ajudar as organizações na implementação dos CIS Controls, a saber:

Guia de Implementação (Implementation Guide): detalha as ações específicas a serem tomadas para implementar cada controle e subcontrole. Ele fornece instruções passo a passo para ajudar as organizações a aplicar as melhores práticas de segurança;

Guia de Avaliação (Assessment Guide): ajuda as organizações a avaliar o seu compliance com os controles dos CIS e a medir seu progresso na implementação; e

Guia de Mapeamento (Mapping Guide): ajuda a relacionar os controles dos CIS com outros padrões e regulamentações de Segurança Cibernética, como por exemplo o NIST Cybersecurity Framework e a ISO 27001.

1.5 Perfis

Os CIS Controls oferecem a flexibilidade de adaptação para diferentes organizações e cenários de risco. Os "Perfis" possibilitam que as organizações personalizem a implementação dos controles para atender às suas necessidades específicas.

Os perfis são classificados como:

- **Perfil Básico (*Basic Profile*):** adequado para organizações com recursos limitados de Segurança Cibernética;
- **Perfil Empresarial (*Enterprise Profile*):** projetado para organizações maiores com equipes de segurança cibernética mais robustas; e
- **Perfil Avançado (*Advanced Profile*):** destinado a organizações com um alto nível de maturidade em Segurança Cibernética.

Em resumo, os CIS Controls são um conjunto abrangente de melhores práticas de segurança cibernética que ajudam as organizações a fortalecer sua postura de segurança, protegendo seus sistemas e dados contra ameaças cibernéticas. Eles oferecem orientações claras, estrutura e flexibilidade para personalização, tornando-os valiosos para uma ampla gama de organizações.

1.6 Visão geral dos CIS Controls

O CIS Controls é uma iniciativa iniciada nos anos 2000, como uma atividade básica para identificar ataques cibernéticos. Sob a responsabilidade da organização não governamental Center for Internet Security Os IGS dos controles do CIS são categorias autoavaliadas para empresas, e cada um possui um conjunto de medidas. Um IG estabelece um subconjunto dos Controles CIS. Os referidos IGS apresentam uma visão horizontal dos CIS Controles. Segundo CIS Controls V8, os controles apresentam:

- Uma breve descrição da intenção do controle e sua utilidade como ação defensiva;
- Uma descrição da importância do controle no bloqueio, mitigação ou identificação de ataques, e uma explicação de como os invasores utilizam ativamente a ausência do referido controle;
- Uma descrição técnica dos processos e tecnologias que permitem a implementação e automação do referido controle;
- Uma tabela das ações específicas que as empresas devem realizar para implementar o controle.

O CIS Controls V8 possui 18 controles, a saber:

Controle 1 – Inventário e controle de ativos corporativos

É um controle que busca identificar, gerenciar e proteger os ativos de hardware e software da organização. A importância desse controle está relacionada à necessidade de saber exatamente o que existe em uma rede ou ambiente de tecnologia da informação, para que a organização possa implementar os controles apropriados para proteger seus ativos de forma eficaz e responder rapidamente a ameaças cibernéticas. A figura 18 traz as etapas do controle 1.



Etapas do controle 1.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 2 – Inventário e controle de ativos de software

É um controle que busca gerenciar os ativos de tecnologia da informação com foco na identificação, rastreamento e gestão de todos os programas de software utilizados na organização. Essa prática é essencial para assegurar o *compliance* das licenças de software, otimizar recursos de tecnologia da informação e mitigar riscos de Segurança Cibernética relacionados a softwares desatualizados ou não autorizados. A figura 19 traz as etapas do controle 2.

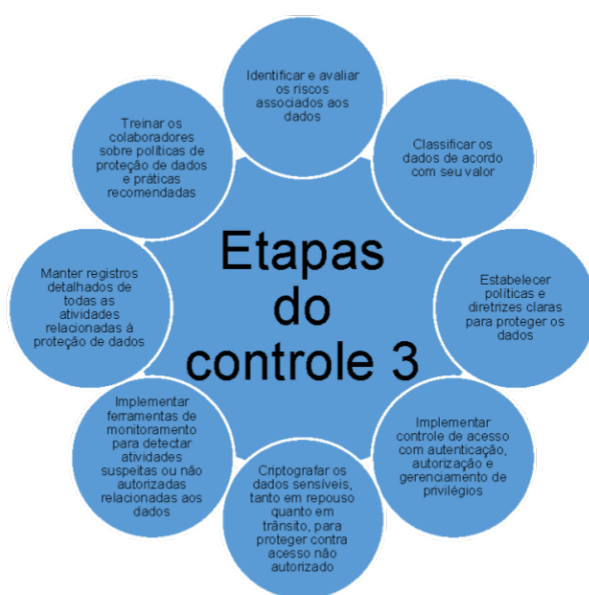


Etapas do controle 2.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 3 – Proteção de dados

É um controle que busca implementar medidas e práticas destinadas a garantir a confidencialidade, integridade, disponibilidade e autenticidade dos dados armazenados, processados e transmitidos pela organização. Esse controle busca desenvolver processos e controles técnicos para classificar, manusear com segurança, reter e descartar os dados. A figura 20 traz as etapas do controle 3.



Etapas do controle 3 .

Fonte: Adaptado de Center for Internet Security (2023).

Controle 4 – Configuração segura de ativos corporativos e *software*

É um controle que busca implementar medidas e práticas destinadas a garantir a confidencialidade, integridade, disponibilidade e autenticidade dos dados armazenados, processados e transmitidos pela organização. Esse controle busca desenvolver processos e controles técnicos para classificar, manusear com segurança, reter e descartar os dados. A figura 20 traz as etapas do controle 3.



Etapas do controle 5.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 5 – Gestão de contas

É um controle que busca atribuir e gerenciar autorização de credenciais para contas de administrador, usuário e serviços. Esse controle considera a administração, revisão e desativação das contas nos sistemas, aplicativos e redes da organização. A figura 22 traz as etapas do controle 5.



Etapas do controle 5.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 6 – Gestão de controle de acesso

É um controle que busca controlar e gerenciar quem tem permissão para acessar recursos, sistemas e informações dentro da organização. Esse controle estabelece processos e utiliza ferramentas para criar, atribuir, gerenciar e revogar credenciais de acesso e privilégios de contas de administrador, usuário e serviços para ativos de softwares corporativos. A figura 23 traz as etapas do controle 6.



Etapas do controle 6.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 7 – Gestão contínua de vulnerabilidades

É um controle que busca identificar, avaliar e mitigar as vulnerabilidades dos sistemas, aplicativos e infraestrutura de tecnologia da informação de uma organização. Esse controle desenvolve um plano para rastrear as vulnerabilidades regularmente dos ativos corporativos na infraestrutura da organização. A figura 24 traz as etapas do controle 7.



Etapas do controle 7.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 8 – Gestão de registro de auditoria

É um controle que busca capturar, armazenar, analisar, monitorar e reter os logs de auditoria de eventos que podem ajudar a detectar, compreender e se recuperar de um ataque. A figura 25 traz as etapas do controle 8.



Etapas do controle 8.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 9 – Proteções de e-mail e navegador Web

É um controle que busca estruturar as proteções e detecções de vetores de ameaças de e-mail e navegador web. Esses controles são projetados para proteger as organizações contra ameaças online. A figura 26 traz as etapas do controle 9.



Etapas do controle 9.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 10 – Defesa contra *malware*

É um controle que busca proteger os sistemas de computadores e redes para impedir ou controlar a instalação, disseminação e processamento de aplicações, códigos ou *scripts* maliciosos em ativos corporativos. A figura 27 traz as etapas do controle 10.

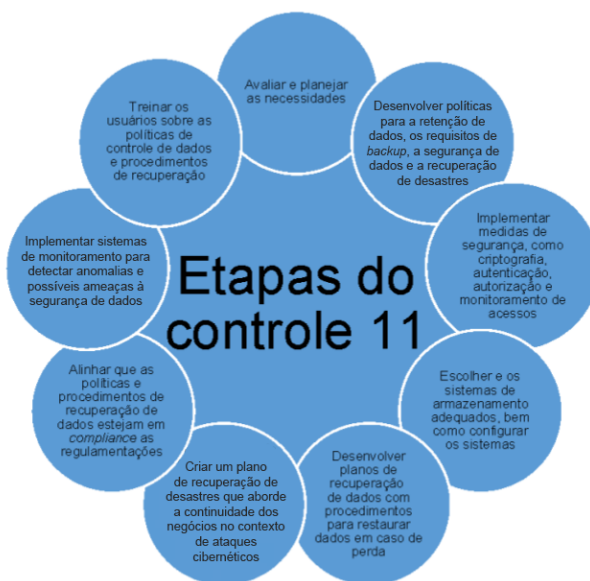


Etapas do controle 10.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 11 – Recuperação de dados

É um controle que busca estabelecer e manter práticas de recuperação de dados no contexto da capacidade de armazenar, gerenciar, proteger e, quando necessário restaurar as informações de valor dos dispositivos de armazenamento e sistemas computacionais. A figura 28 traz as etapas do controle 11.

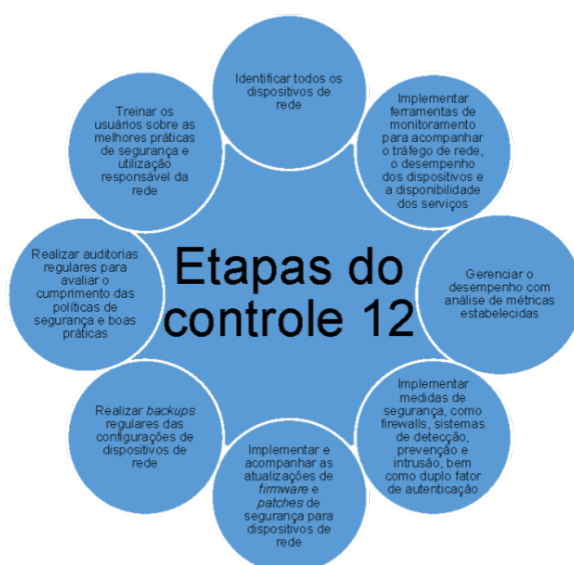


Etapas do controle 11.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 12 – Gestão da infraestrutura de rede

É um controle que busca estabelecer, implementar e gerenciar os dispositivos de rede. A gestão da infraestrutura de rede permite manter atualizados os dispositivos como *gateways* físicos e virtualizados, *firewalls*, pontos de acesso sem fio, roteadores e switches. A figura 29 traz as etapas do controle 12.

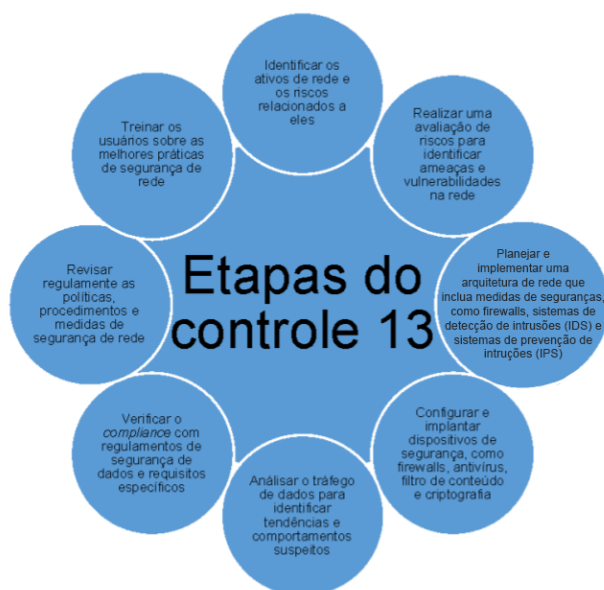


Etapas do controle 12.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 13 – Monitoramento e defesa da rede

É um controle que busca implementar processos e ferramentas para estabelecer e manter monitoramento e a defesa holística da rede contra a dinâmica das ameaças cibernéticas para os usuários e o ambiente digital da organização. A figura 30 traz as etapas do controle 13.

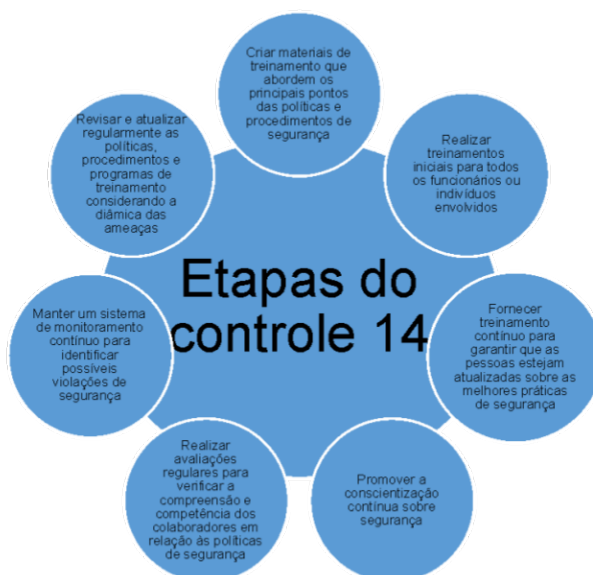


Etapas do controle 13.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 14 – Conscientização sobre segurança e treinamento de competências

É um controle que busca implementar um programa de conscientização de segurança na organização. Esse programa fomenta o conhecimento dos colaboradores para identificar e responder adequadamente a riscos de segurança, vulnerabilidades e incidentes. Com isso, fortalecer o comportamento de segurança cibernética na organização e qualificar a força de trabalho. A figura 31 traz as etapas do controle 14.

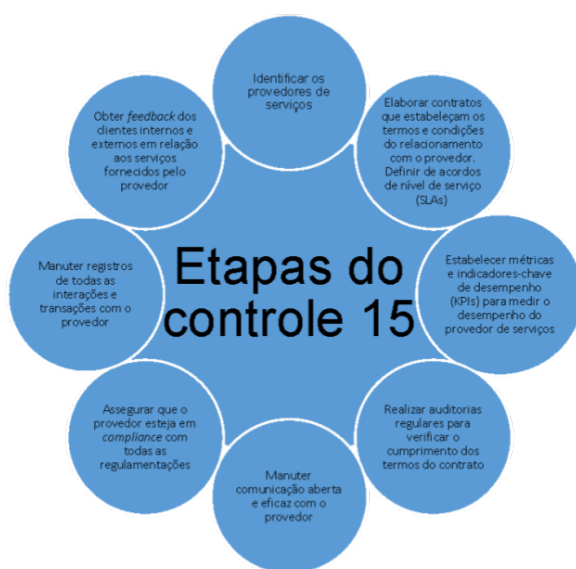


Etapas do controle 14.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 15 – Gestão de provedor de serviço

É um controle que busca avaliar as atividades dos provedores de serviço de tecnologia da informação para assegurar que esses provedores realizem de forma adequada a proteção das plataformas de tecnologia da informação e dos dados. A figura 32 traz as etapas do controle 15.

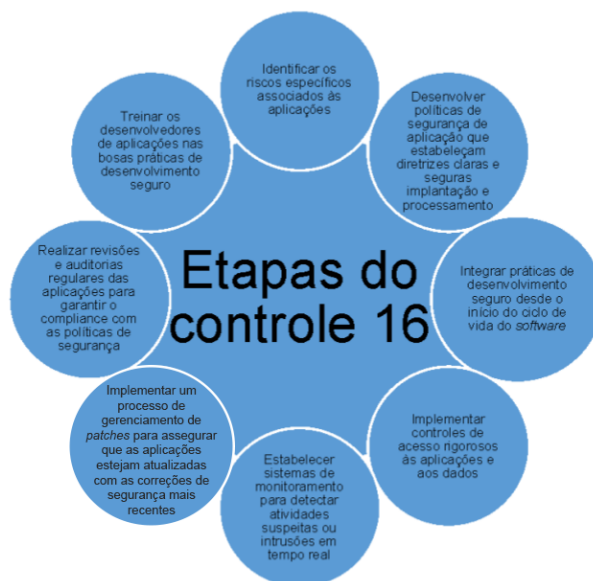


Etapas do controle 15.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 16 – Segurança de aplicações

É um controle que busca assegurar que as aplicações de software utilizadas na organização estejam desenvolvidas, implantadas e mantidas de forma segura, para proteção contra ameaças e vulnerabilidades que possam impactar a confidencialidade, integridade, disponibilidade e autenticidade dos dados, informações e sistemas. A figura 33 traz as etapas do controle 16.

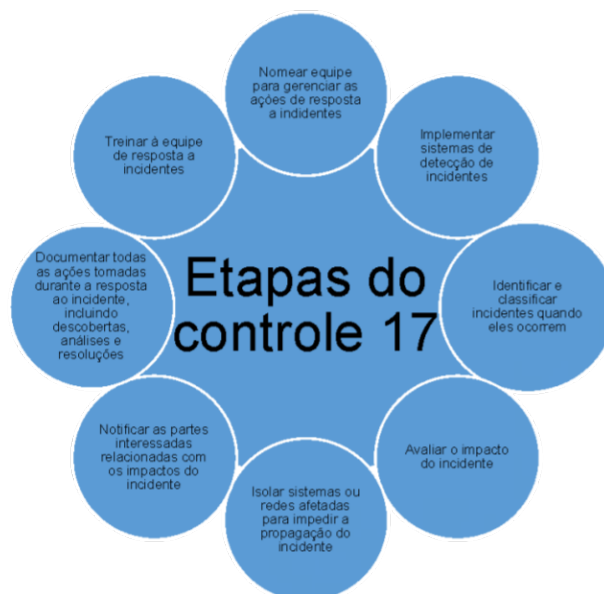


Etapas do controle 16.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 17 – Gestão de resposta a incidentes

É um controle que busca identificar, avaliar e responder de forma eficaz a incidentes de segurança. A gestão de resposta a incidentes estabelece a definição clara e objetiva dos papéis e responsabilidades das equipes participantes das ações de resposta aos incidentes de segurança cibernética. A figura 34 traz as etapas do controle 17.

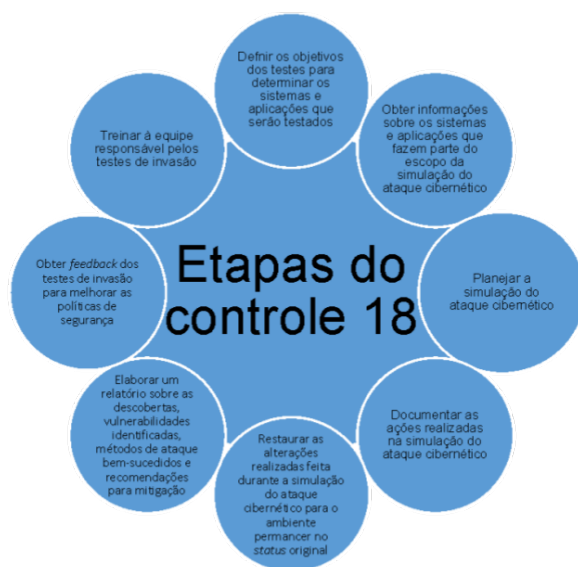


Etapas do controle 17.

Fonte: Adaptado de Center for Internet Security (2023).

Controle 18 – Testes de invasão

É um controle que busca testar a eficácia e a resiliência dos ativos corporativos para identificar vulnerabilidades que possam ser utilizadas pelos atacantes. Para tanto, são realizadas simulações controladas de ataques cibernéticos contra os sistemas e redes da organização. A figura 30 traz as etapas do controle 18.



Etapas do controle 18.

Fonte: Adaptado de Center for Internet Security (2023).

Os 18 controles mencionados refletem o conhecimento de especialistas dos times respostas e analistas de ameaças, tecnólogos, operadores e defensores de tecnologia da informação, pesquisadores de vulnerabilidades, fabricantes de ferramentas, provedores de solução e formuladores de políticas de segurança (CENTER FOR INTERNET SECURITY, CIS CONTROLS, 2023).

Referências

CENTER FOR INTERNET SECURITY, CIS CONTROLS, Disponível em: <https://www.cisecurity.org/>. Acesso em: 21 de agosto de 2023.

Glossário

Termo:	Definição / significado:
Aceitação de riscos	processo para classificar os riscos como aceitáveis, considerando se o custo de mitigação for maior do que o próprio risco
Análise de Custo – Benefício	antes de implementar medidas de mitigação, a organização avalia se os custos associados à mitigação superam os benefícios esperados em termos de redução de risco
Análise dos riscos	uso sistemático de informações para identificar fontes e estimar o risco
Avaliação de riscos	processo de comparar o risco estimado com critérios de risco predefinidos para determinar a importância do risco
CIS Controls	É um conjunto de melhores práticas destinadas a reduzir o risco de ameaças cibernéticas. Eles fornecem orientações detalhadas sobre a implementação de controles de segurança eficazes.
CMMC (Cybersecurity Maturity Model Certification)	É um framework desenvolvido pelo Departamento de Defesa dos EUA para avaliar e aprimorar a Segurança Cibernética em organizações contratadas pelo governo. Ele define diferentes níveis de maturidade em Segurança Cibernética, exigindo que as empresas atendam a determinados requisitos para obter contratos governamentais.
COBIT (Control Objectives for Information and Related Technologies)	É um framework desenvolvido pelo ISACA que se concentra na governança de tecnologia da informação. Ele ajuda as organizações a estabelecer um ambiente de controle sólido, garantindo que a área de tecnologia da informação esteja alinhada com os objetivos da organização e em conformidade com as regulamentações relacionadas com a Segurança Cibernética.
Comunicação de Riscos	processo para compartilhar informações sobre riscos com as partes interessadas internas e externas, garantindo transparência e ação coordenada

Controle 1 – Inventário e controle de ativos corporativos	Controle que busca identificar, gerenciar e proteger os ativos de hardware e software da organização. A importância desse controle está relacionada à necessidade de saber exatamente o que existe em uma rede ou ambiente de tecnologia da informação, para que a organização possa implementar os controles apropriados para proteger seus ativos de forma eficaz e responder rapidamente a ameaças cibernéticas.
Controle 10 – Defesa contra malware	É um controle que busca proteger os sistemas de computadores e redes para impedir ou controlar a instalação, disseminação e processamento de aplicações, códigos ou scripts maliciosos em ativos corporativos.
Controle 11 – Recuperação de dados	É um controle que busca estabelecer e manter práticas de recuperação de dados no contexto da capacidade de armazenar, gerenciar, proteger e, quando necessário restaurar as informações de valor dos dispositivos de armazenamento e sistemas computacionais.
Controle 12 – Gestão da infraestrutura de rede	É um controle que busca estabelecer, implementar e gerenciar os dispositivos de rede. A gestão da infraestrutura de rede permite manter atualizados os dispositivos como gateways físicos e virtualizados, firewalls, pontos de acesso sem fio, roteadores e switches.
Controle 13 – Monitoramento e defesa da rede	É um controle que busca implementar processos e ferramentas para estabelecer e manter monitoramento e a defesa holística da rede contra a dinâmica das ameaças cibernéticas para os usuários e o ambiente digital da organização.
Controle 14 – Conscientização sobre segurança e treinamento de competências	É um controle que busca implementar um programa de conscientização de segurança na organização. Esse programa fomenta o conhecimento dos colaboradores para identificar e responder adequadamente a riscos de segurança, vulnerabilidades e incidentes. Com isso, fortalecer o comportamento de segurança cibernética na organização e qualificar a força de trabalho.
Controle 15 – Gestão de provedor de serviço	É um controle que busca avaliar as atividades dos provedores de serviço de tecnologia da informação para assegurar que esses provedores realizem de forma adequada a proteção das plataformas de tecnologia da informação e dos dados.
Controle 16 – Segurança de aplicações	É um controle que busca assegurar que as aplicações de software utilizadas na organização estejam desenvolvidas, implantadas e mantidas de forma segura, para proteção contra ameaças e vulnerabilidades que possam impactar a confidencialidade, integridade, disponibilidade e autenticidade dos dados, informações e sistemas.

Controle 17 – Gestão de resposta a incidentes	É um controle que busca identificar, avaliar e responder de forma eficaz a incidentes de segurança. A gestão de resposta a incidentes estabelece a definição clara e objetiva dos papéis e responsabilidades das equipes participantes das ações de resposta aos incidentes de segurança cibernética.
Controle 18 – Testes de invasão	É um controle que busca testar a eficácia e a resiliência dos ativos corporativos para identificar vulnerabilidades que possam ser utilizadas pelos atacantes. Para tanto, são realizadas simulações controladas de ataques cibernéticos contra os sistemas e redes da organização.
Controle 2 – Inventário e controle de ativos de software	É um controle que busca gerenciar os ativos de tecnologia da informação com foco na identificação, rastreamento e gestão de todos os programas de software utilizados na organização. Essa prática é essencial para assegurar o compliance das licenças de software, otimizar recursos de tecnologia da informação e mitigar riscos de Segurança Cibernética relacionados a softwares desatualizados ou não autorizados.
Controle 3 – Proteção de dados	É um controle que busca implementar medidas e práticas destinadas a garantir a confidencialidade, integridade, disponibilidade e autenticidade dos dados armazenados, processados e transmitidos pela organização. Esse controle busca desenvolver processos e controles técnicos para classificar, manusear com segurança, reter e descartar os dados.
Controle 4 – Configuração segura de ativos corporativos e software	É um controle que busca definir, gerenciar e manter as configurações de segura dos ativos corporativos e software para assegurar que eles estejam adequadamente protegidos contra ameaças cibernéticas e funcionem de maneira eficaz.
Controle 5 – Gestão de contas	É um controle que busca atribuir e gerenciar autorização de credenciais para contas de administrador, usuário e serviços. Esse controle considera a administração, revisão e desativação das contas nos sistemas, aplicativos e redes da organização.
Controle 6 – Gestão de controle de acesso	É um controle que busca controlar e gerenciar quem tem permissão para acessar recursos, sistemas e informações dentro da organização. Esse controle estabelece processos e utiliza ferramentas para criar, atribuir, gerenciar e revogar credenciais de acesso e privilégios de contas de administrador, usuário e serviços para ativos de softwares corporativos.

Controle 7 – Gestão contínua de vulnerabilidades	É um controle que busca identificar, avaliar e mitigar as vulnerabilidades dos sistemas, aplicativos e infraestrutura de tecnologia da informação de uma organização. Esse controle desenvolve um plano para rastrear as vulnerabilidades regularmente dos ativos corporativos na infraestrutura da organização.
Controle 8 – Gestão de registro de auditoria	É um controle que busca capturar, armazenar, analisar, monitorar e reter os logs de auditoria de eventos que podem ajudar a detectar, compreender e se recuperar de um ataque.
Controle 9 – Proteções de e-mail e navegador Web	É um controle que busca estruturar as proteções e detecções de vetores de ameaças de e-mail e navegador web. Esses controles são projetados para proteger as organizações contra ameaças online.
Controle dos riscos	medidas implementadas para reduzir a probabilidade de um evento de risco ou seu impacto. Eles podem ser técnicos, operacionais ou administrativos
Cultura de Riscos	processo para implementar um conjunto de práticas de sensibilização, conscientização e treinamentos para tornar o ambiente corporativo alinhado com a gestão de riscos
Disponibilidade	Propriedade pela qual se assegura que a informação esteja acessível e utilizável, sob demanda, por uma pessoa física ou determinado sistema, órgão ou entidade devidamente autorizados;
FISMA (Federal Information Security Management Act)	É uma legislação dos EUA que exige que as agências federais desenvolvam, implementem e mantenham programas de Segurança da Informação, bem como diretrizes robustas para a Segurança Cibernética no setor público.
Gestão de incidentes cibernéticos	processo que realiza ações sobre qualquer evento adverso relacionado à Segurança Cibernética dos sistemas ou da infraestrutura de computação
Gestão de incidentes de Segurança da Informação	processo que visa integrar atividades de gestão de riscos, gestão de continuidade do negócio, tratamento de incidentes, tratamento da informação, conformidade, credenciamento, segurança cibernética, segurança física, segurança lógica, segurança orgânica e organizacional, aos processos institucionais estratégicos, operacionais e táticos, não se limitando, portanto, à tecnologia da informação
Identificação de riscos	processo de localizar, listar e caracterizar elementos de risco

Incidente	interrupção não planejada ou redução da qualidade de um serviço, ou seja, ocorrência, ação ou omissão, que tenha permitido, ou possa vir a permitir, acesso não autorizado, interrupção ou mudança nas operações (inclusive pela tomada de controle), destruição, dano, deleção ou mudança da informação protegida, remoção ou limitação de uso da informação protegida ou ainda a apropriação, disseminação e publicação indevida de informação protegida de algum ativo de informação crítico ou de alguma atividade crítica por um período de tempo inferior ao tempo objetivo de recuperação
Incidente Cibernético	ocorrência que pode comprometer, real ou potencialmente, a disponibilidade, a integridade, a confidencialidade ou a autenticidade de sistema de informação ou das informações processadas, armazenadas ou transmitidas por esse sistema. Poderá também ser caracterizada pela tentativa de exploração de vulnerabilidade de sistema de informação que caracterize violação de norma, política de segurança, procedimento de segurança ou política de uso. De maneira geral, os tipos de atividade comumente reconhecidas como incidentes cibernéticos são: a) tentativas de obter acesso não-autorizado a um sistema ou a dados armazenados; b) tentativa de utilização não-autorizada de sistemas para a realização de atividades de processamento ou armazenamento de dados; c) mudanças não-autorizadas de firmware, hardware ou software em um ambiente computacional; d) ataques de negação de serviço (DDoS); e e) demais ações que visem afetar a disponibilidade ou integridade dos dados. Um incidente de segurança cibernética não significa necessariamente que as informações já estão comprometidas; significa apenas que a informação está ameaçada
Incidente de segurança	qualquer evento adverso, confirmado ou sob suspeita, relacionado à segurança dos sistemas de computação ou das redes de computadores
ISO 27001/27002	É uma norma internacional para sistemas de gestão de Segurança da Informação. Ela fornece um conjunto de requisitos para estabelecer, implementar, manter e melhorar um sistema de gestão de segurança da informação. A ISO 27002, estabelece diretrizes detalhadas para a implementação dos controles de Segurança da Informação.

ITIL (Information Technology Infrastructure Library)	O ITIL é mais conhecido por seus processos de gerenciamento de serviços de tecnologia da informação. No entanto, o ITIL apresenta práticas relacionadas à Segurança Cibernética. Ajuda as organizações a integrar a Segurança Cibernética em suas operações de tecnologia da informação.
Mitigação de riscos	processo de ações para reduzir a probabilidade do impacto dos riscos, considerando a implementação de controles de segurança
MITRE ATT&CK	É um modelo de matriz de táticas e técnicas de ataque cibernético. Fornece uma estrutura que permite entender as táticas e técnicas que os adversários cibernéticos podem utilizar, e ajuda na melhoria para a detecção e a resposta a ameaças.
Monitoramento dos Riscos	a gestão de riscos é um processo contínuo de monitoramento, que demanda um método para acompanhar a eficácia das ações de mitigação e identificar mudanças nos riscos ao longo do tempo
NICE Framework (National Initiative for Cybersecurity Education)	Estruturado pelo governo dos EUA. Esse framework define funções e especializações em Segurança Cibernética e fornece orientações para o desenvolvimento de força de trabalho em Segurança Cibernética
NIST Cybersecurity Framework	Desenvolvido pelo Instituto Nacional de Padrões e Tecnologia (NIST) dos EUA, esse framework apresenta diretrizes para ajudar as organizações a melhorar sua postura de Segurança Cibernética. Ele é composto por funções para identificar, proteger, detectar, responder e recuperar.
NIST SP 800-53	É um conjunto de controles de segurança desenvolvido pelo NIST dos EUA para uso em agências federais. É referenciado e adotado por organizações públicas e privadas para estabelecer medidas de segurança abrangentes.
Plano de Resposta a Riscos	plano estruturado que detalha como a organização responderá a eventos adversos caso ocorram. Ele inclui etapas de resposta, atribuições e recursos necessários
Risco de Segurança da Informação	risco potencial associado à exploração de uma ou mais vulnerabilidades de um ou mais ativos de informação, por parte de uma ou mais ameaças, com impacto negativo no negócio da organização
Transferência dos riscos	forma de tratamento de risco na qual a alta administração decide realizar a atividade, compartilhando com outra entidade o ônus associado a um risco